

Healthcare Interoperability & Prior Authorization Platform

Architecture, Business Model, Technical Design & Implementation Roadmap

Medblocks-Inspired Interoperability Architecture
for Automated Prior Authorization

Document control	Value
Version / date	1.0 30 September 2026
Audience	CTO, CEO, architecture, product, engineering, healthcare SMEs and technical partners
Status	Research-backed proposal; implementation and partner validation pending
Working scope	US provider-side medical PA; pharmacy and enterprise extensions explicitly separated
Data boundary	Synthetic data until security/privacy approvals and vendor agreements
Independence	Not affiliated with Medblocks; no proprietary internals asserted

Includes source-linked research, architecture and sequence diagrams, API/data contracts, proposed decisions, delivery gates and implementation estimates.

Contents

Clickable section links and PDF bookmarks. Numbered sections split long topics for readability.

- 01. Executive summary / 5
- 02. Business problem and success measures / 6
- 03. Assumptions, evidence and reading guide / 7
- 04. Healthcare ecosystem: actors and ownership / 8
- 05. Healthcare ecosystem: platform and interfaces / 9
- 06. What Medblocks publicly documents / 10
- 07. Medblocks logical architecture and data flow / 11
- 08. Medblocks connection and patient-access flows / 12
- 09. Medblocks backend and ingestion flows / 13
- 10. Medblocks events, exports and open-source lessons / 14
- 11. Medblocks developer and operational model / 15
- 12. Platform vision and business architecture / 16
- 13. Target technical architecture / 17
- 14. Platform component inventory: access and data / 18
- 15. Platform component inventory: PA and operations / 19
- 16. EHR connectivity comparison / 20
- 17. Payer connectivity and exchange directions / 21
- 18. FHIR, profiles and exchange standards / 22
- 19. SMART authorization and connection security / 23
- 20. Ingestion and clinical data quality / 24
- 21. HIE and network strategy / 25
- 22. Legacy interfaces and normalization boundaries / 26
- 23. Data architecture: conceptual and storage model / 27
- 24. Data dictionary: tenancy, identity and connectivity / 28
- 25. Data dictionary: PA, evidence and operations / 29
- 26. Example schema and FHIR resources / 30
- 27. Synthetic resource and API examples / 31
- 28. Terminology architecture / 32
- 29. Prior Authorization business workflow / 33
- 30. PA lifecycle and exception flow / 34
- 31. CMS requirements and version baseline / 35
- 32. CRD, DTR and PAS relationship / 36

Contents (continued)

Clickable section links and PDF bookmarks. Numbered sections split long topics for readability.

- 33. CRD and DTR implementation contracts / 37
- 34. Medical PA sequence and PAS behavior / 38
- 35. Technical PA step contracts: intake and evidence / 39
- 36. Technical PA step contracts: exchange and closure / 40
- 37. API architecture and common contract / 41
- 38. API catalog: connections and clinical records / 42
- 39. API catalog: PA, documents and events / 43
- 40. Connector architecture and onboarding / 44
- 41. FHIR server strategy and decision / 45
- 42. Security and compliance architecture / 46
- 43. Security controls and operational duties / 47
- 44. PHI boundaries, retention and incident response / 48
- 45. Cloud deployment and environment separation / 49
- 46. Production AWS reference architecture / 50
- 47. Multi-tenancy and isolation / 51
- 48. Reliability and failure architecture / 52
- 49. Observability, SLOs and disaster recovery / 53
- 50. Admin, developer and operating experience / 54
- 51. Testing and acceptance strategy / 55
- 52. Build, buy, open source and partner decisions / 56
- 53. MVP scope and architecture / 57
- 54. Implementation roadmap: phases 0-3 / 58
- 55. Implementation roadmap: phases 4-7 / 59
- 56. Implementation roadmap: phases 8-10 / 60
- 57. Team structure and governance / 61
- 58. Risk register: integrations and data / 62
- 59. Risk register: governance and operations / 63
- 60. Cost and effort model / 64
- 61. Future-state enterprise architecture / 65
- 62. Consolidated target architecture / 66
- 63. Decision records and immediate execution plan / 67
- 64. Glossary: healthcare and interoperability / 68

Contents (continued)

Clickable section links and PDF bookmarks. Numbered sections split long topics for readability.

- 65. Glossary: security, terminology and software / 69
- 66. Appendix: Matrix A: provider automation and connectivity / 70
- 67. Appendix: Matrix B: payer UM and pharmacy ePA / 71
- 68. Appendix: Matrix C: integration components and substitutes / 72
- 69. Appendix: Workflow coverage crosswalk / 73
- 70. Appendix: Pricing signals and total cost / 74
- 71. References and research transparency / 75
- 72. References and research transparency (continued) / 76
- 73. References and research transparency (continued) / 77
- 74. References and research transparency (continued) / 78
- 75. References and research transparency (continued) / 79
- 76. References and research transparency (continued) / 80
- 77. References and research transparency (continued) / 81
- 78. References and research transparency (continued) / 82
- 79. References and research transparency (continued) / 83
- 80. References and research transparency (continued) / 84
- 81. References and research transparency (continued) / 85
- 82. References and research transparency (continued) / 86
- 83. References and research transparency (continued) / 87
- 84. References and research transparency (continued) / 88
- 85. References and research transparency (continued) / 89

01. Executive summary

Level 1 | Business decision | Architecture proposal v1.0 | 30 September 2026

Build a Healthcare Interoperability & Prior Authorization Platform: a temporary project name for a provider-facing system that connects clinical data to payer requirements, prepares reviewable evidence, submits through supported routes and reconciles decisions. This proposal is independent of, and unaffiliated with, Medblocks.

Executive question	Recommended answer
Why build it?	Reduce repeated data entry, missing documentation and untracked cases between clinical ordering and payer decisions. Measure staff effort and turnaround before claiming savings.
How is it related to Medblocks?	Adopt the documented concepts of authorized connections, background retrieval, source-aware data, events and exports. Do not copy or assert proprietary internals. [26] [27]
How does it enable PA?	Add a durable PA case engine, payer routing, requirements/documentation workflows, reviewed submissions and decision reconciliation on top of interoperability.
Who uses it?	Authorization coordinators, clinicians, integration teams and provider administrators. Patients receive appropriate status; payers remain external decision authorities.
Major components?	Connection control plane, connectors, clinical data/FHIR layer, case and evidence service, CRD/DTR/PAS adapters, staff UI, audit and operations.
Standards?	FHIR R4 with partner-agreed profiles; SMART/OAuth; Da Vinci where supported; X12/intermediary and pharmacy NCPDP paths separately.
MVP?	One provider organization, one specialty, one EHR and one contracted payer/delegate route. Review before submit; reliable pending/information-request handling.
Major risks?	Production access, incomplete data, route differences, policy licensing, identity errors, PHI exposure, missed deadlines and operating cost.

Recommended starting decision: own workflow, provenance and portability; reuse open-source FHIR components and managed infrastructure; partner for network reach where economically justified. A complete national network, autonomous medical decisions and every EHR are outside MVP scope. This is a planning blueprint, not an implemented or certified system.

02. Business problem and success measures

Level 1 | A workflow product supported by interoperability, not a data lake in search of a use case

A clinical order, an insurance benefit and a payer policy live in different systems. Staff must determine whether PA is required, collect the right evidence, send it through the correct channel and keep the case moving. The opportunity is to preserve that chain of responsibility and evidence as work crosses organizational boundaries. CRD explicitly addresses requirements at the point of care. [69]

Problem hypothesis	Product response / measure
Clinical facts are re-entered	Retrieve authorized source data once; retain source/version. Measure net staff minutes, including correction and review.
Requirements are discovered too late	Check during ordering or intake; record authority, policy version and expiry. Measure order-to-ready time.
Status is fragmented	One case timeline with external request IDs, due dates and owners. Measure unreconciled and overdue cases.
Automation hides exception work	Make missing data, unsupported routes and manual work visible. Measure total human interventions, including vendor staff.
Submission success is confused with approval	Separate technical receipt, review state and item-level determination. Measure each transition independently.

Business boundaries

The provider owns the clinical request and attestation. The payer or delegated UM organization owns the coverage determination. Our platform does not guarantee reimbursement, replace clinical judgment or infer that every medically reasonable order is covered. Authorization approval can be constrained by dates, units, service, site and plan.

Commercial hypothesis to validate

Start with provider groups or health systems with repeatable specialty workflows and a willing EHR/payer partner. Expansion to healthcare SaaS, RCM companies and PA vendors can use the same developer APIs. Payer buyers need a separate product/governance path. Interview staff and measure a baseline before locking in a pricing or ROI claim.

03. Assumptions, evidence and reading guide

Verified means supported by a reviewed public source, not independently tested in production.

Label	Meaning in this document
Verified	An official source states the capability or rule; citations identify the scope. Vendor effectiveness claims remain vendor claims.
Industry-standard	A published protocol or established control pattern; cited where applicable. It does not mean every partner implements it.
Recommended	Our proposed design, workflow, estimate or control. Subject to stakeholder approval and engineering validation.
Inferred	A logical decomposition suggested by public behavior; not a disclosed vendor implementation.
Needs validation	Missing partner, legal, performance, security or commercial evidence that must be resolved before commitment.

Assumptions: US medical-service PA first; provider-side buyer; AWS primary cloud; synthetic data until approvals and agreements; one EHR/payer route for MVP; human review before submission; no clinical rule authoring intended to replace payer adjudication. Jurisdiction, specialty, payer plan, region, staffing costs and enterprise isolation commitments remain discovery decisions.

Research uses official CMS/HHS/HealthIT.gov, HL7/IETF/OIDC, vendor and network documentation. Source dates appear when available; review date is 30 September 2026. Undated pages are explicitly marked rather than assigned a fabricated publication date. Moving documentation is not a pinned production contract.

Reading paths: executives can read the summary, business model, MVP, roadmap, risks and estimates. Product/SME readers should add ecosystem, PA responsibility and exception flows. Engineers should read the complete API, data, connector, security and deployment sections. The companion README contains source categories and a requirement-to-section index.

Research completed; system not implemented. No vendor integration, conformance, load, clinical validation or production security test was executed for this blueprint. PDF/source and example-JSON checks are document QA only. Existing PA-003 reference research is supporting context, not proof of vendor readiness.

04. Healthcare ecosystem: actors and ownership

Level 2 | Ownership means business stewardship; it does not assert exclusive legal ownership of records.

Actor	Generates / stewards	Needs from others
Patient	Identity assertions, preferences, symptoms, permitted access choices	Care, understandable status, rights and access to records
Clinician	Orders, assessments, notes and attestations	Longitudinal context and actionable requirements
Provider organization	Care delivery, encounter/order records, billing identity	Eligibility, requirements, receipt and decisions
Hospital / clinic / health system	Inpatient/outpatient workflows; system-level governance	Cross-site coordination and consistent operations
EHR vendor / EHR	Software and interfaces / customer clinical record system	Configured clients, scopes, authorized users and data contracts
Payer / insurance plan	Coverage administration / benefit product and policy rules	Member identity, request and medical-necessity evidence
UM organization	Delegated review workflow and determinations within authority	Payer rules, documentation and provider follow-up
Pharmacy / PBM	Dispensing records / pharmacy-benefit administration	Prescription, benefit response and medication ePA
HIE / network	Exchange services and directories	Participation, identity resolution and permitted purpose
Clearinghouse	Transaction transformation/routing and acknowledgments	Correct identifiers, partner enrollment and message contracts

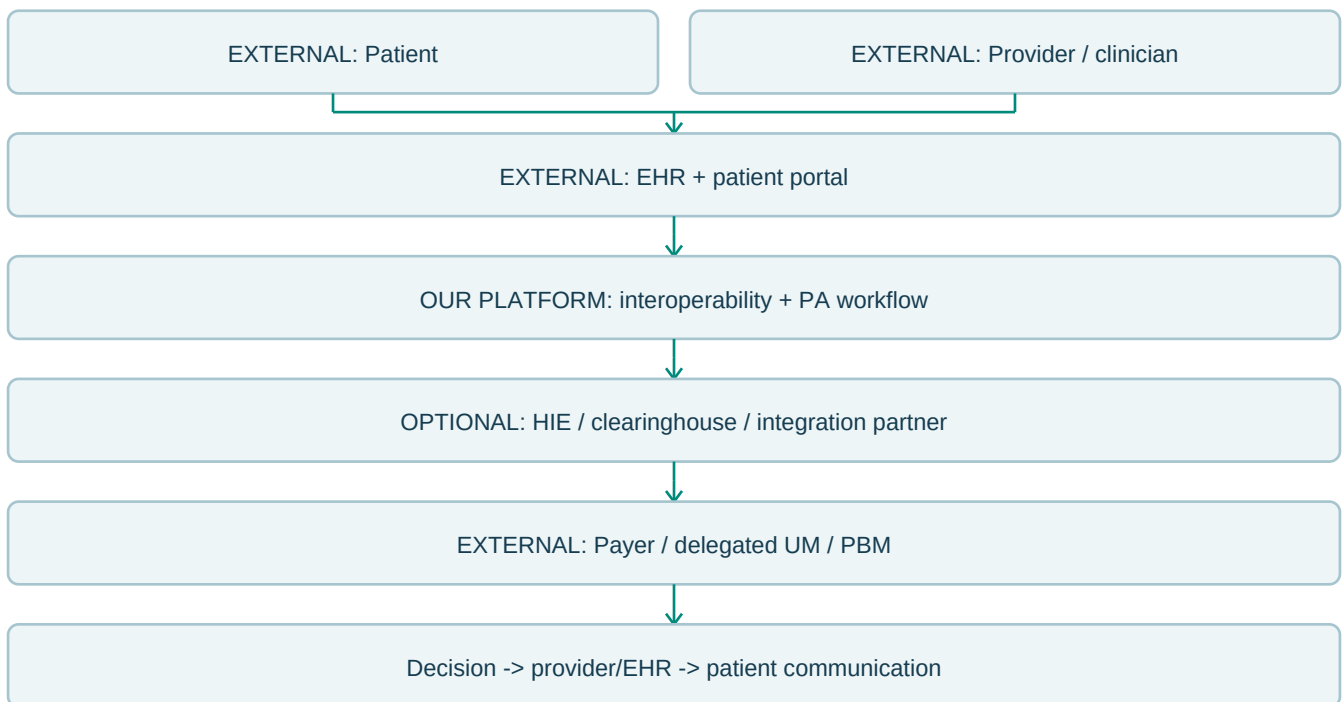
A provider is a care-delivery actor; an EHR is software holding the record; a payer administers coverage. An HIE exchanges records across organizations, while a clearinghouse commonly routes administrative transactions. One company may offer several roles, but permissions and responsibilities remain distinct. TEFCA is a trust framework, not a universal PA endpoint. [\[53\]](#)[\[54\]](#)[\[55\]](#)

05. Healthcare ecosystem: platform and interfaces

Level 2 | Context and trust boundaries

Actor / component	Stewards	Needs
Interoperability platform	Connections, mappings, retrieval jobs and data provenance	Authorized source access and destination contracts
PA platform	Case lifecycle, reviewed requests, follow-up and decision record	Clinical data, coverage, requirements and payer route
FHIR server	Versioned FHIR resources and supported API interactions	Profiles, access controls, persistence and terminology
Integration vendor	Connector/API implementation and operational support	Partner access and scoped service responsibilities
Patient portal	Patient-facing access and communication experience	Identity, authorized records and understandable status

Diagram 1. Overall system context



Recommended context. Optional intermediaries are route-dependent; direct payer routes can bypass that row. Requests travel down; decisions return to the case service and authorized recipients.

Patient-mediated data access can enrich a chart but is not permission to submit a request as a provider. Similarly, an HIE record exchange relationship does not establish the payer transaction relationship. Onboard these independently and preserve their purpose, organization and credentials.

06. What Medblocks publicly documents

Verified product description; no assertion about private implementation or PA submission

Capability	Publicly documented scope
Product and customer	Integration for teams building healthcare applications, through SDK, REST, dashboard, exports and webhooks. [26]
Connection model	Sources represent systems; connections represent authorized relationships for patient, organization or workflow access. [27][28]
Patient access	Patient signs into a source and authorizes record access. Listed guides cover major EHRs and some payer sources; not a PA route matrix. [29]
Clinician workflow	SMART launch and CDS Hooks embed an application with chart context; organizational relationship required. Docs WIP. [24]
Backend	Organization-authorized unattended retrieval; source-specific credentials and monitoring. Docs WIP. [30]
Network	Relationship/permitted-purpose-dependent record discovery and retrieval; not a self-serve universal entitlement. Docs WIP. [31]
Data models	Clinical domain shapes retain source context/provenance alongside original records. Exact internal schema and database are not disclosed here. [35]
Operations	Pull history, token-refresh failure, export runs and event delivery are described. [32][33][34]

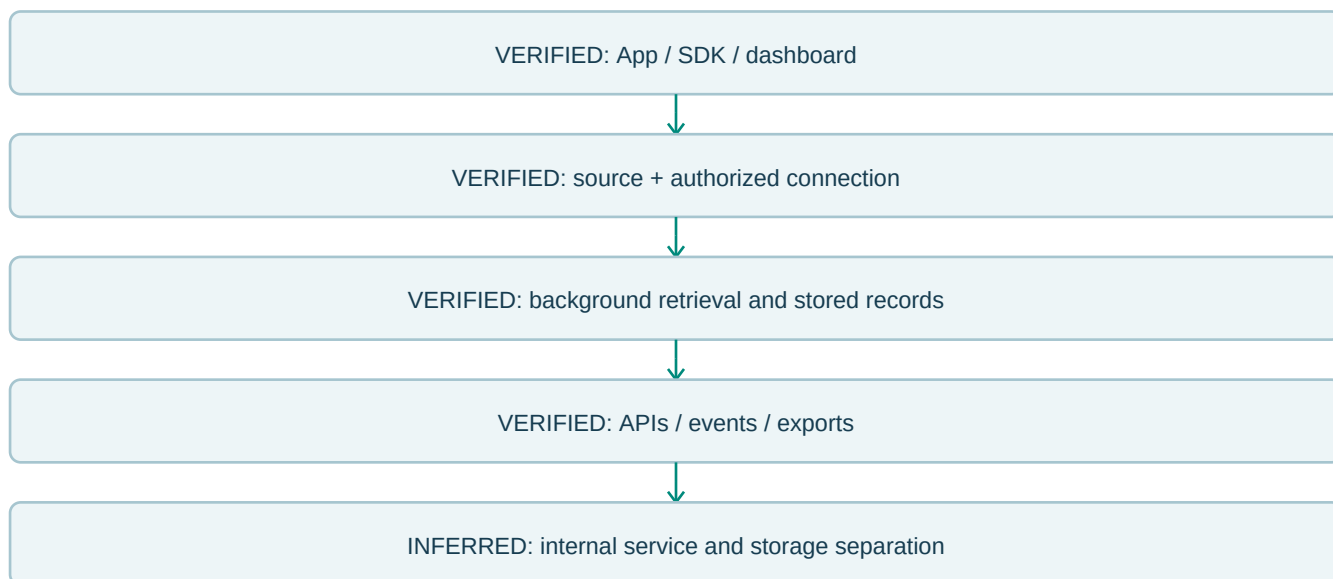
Verified: the separate Medblocks Stack material describes FHIR, openEHR, SMART and S3-compatible APIs for an organization-specific Digital Health Platform. It is not evidence that current Connect uses that precise storage/deployment topology. Some historical Stack statements concern a narrower scope than current network docs. Do not collapse them into one timeless architecture. [36]

Needs validation: contracted source coverage, performance, retention, residency, security evidence, writeback support and production onboarding. PA submission is not established by the Medblocks material reviewed. Our proposed PA engine is an additional product layer.

07. Medblocks logical architecture and data flow

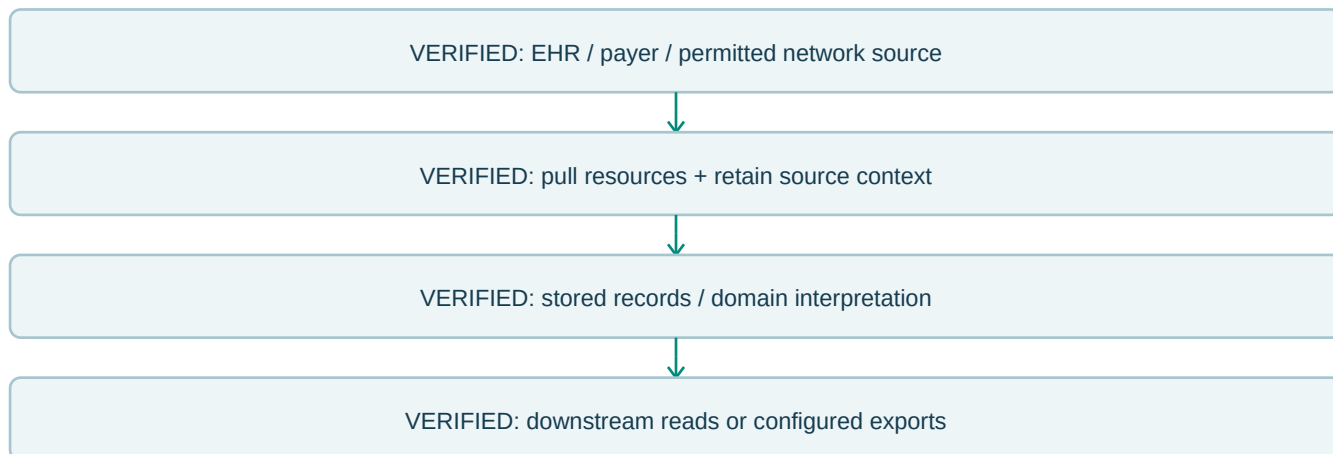
Verified behavior reconstructed as logical boxes; internal services are not claimed.

Medblocks A. Logical architecture



Sources [26][27][32]. The inferred row is a conceptual decomposition only; database, queue, cloud and microservice choices are unknown.

Medblocks B. Data flow



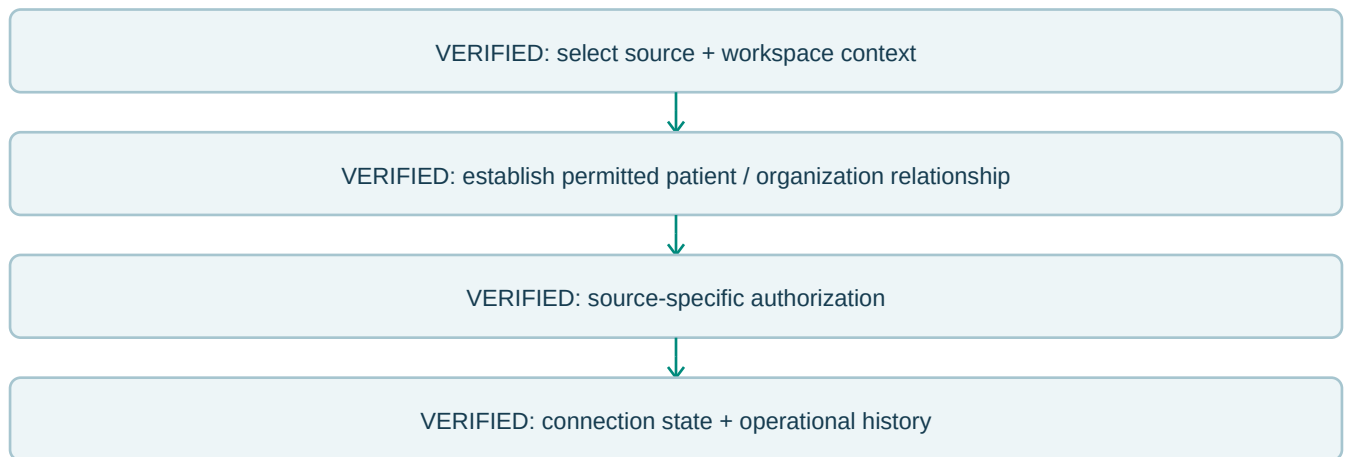
Sources [32][33][35]. Domain models do not imply every code is semantically equivalent or every source resource is complete.

Lesson for our platform: expose access status, retrieval status, data completeness and export status separately. A browser return or connection success must never be presented to PA staff as proof that all required notes and observations have arrived.

08. Medblocks connection and patient-access flows

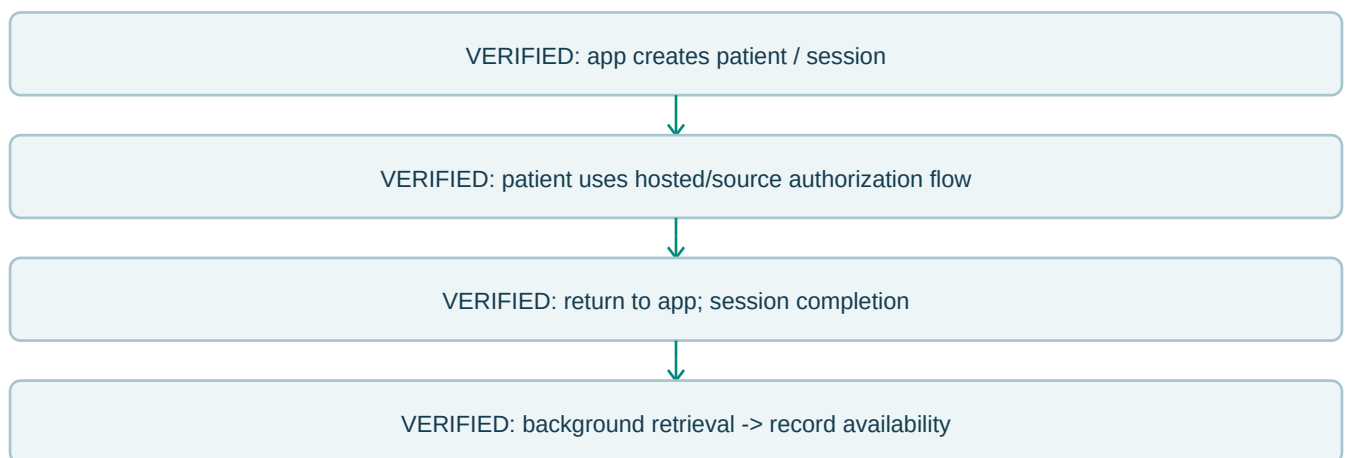
Verified logical sequence; exact screens and source grants vary.

Medblocks C. Connection flow



Sources [28][29][30]. An authorized connection is distinct from a clinical PA case.

Medblocks D. Patient-access flow



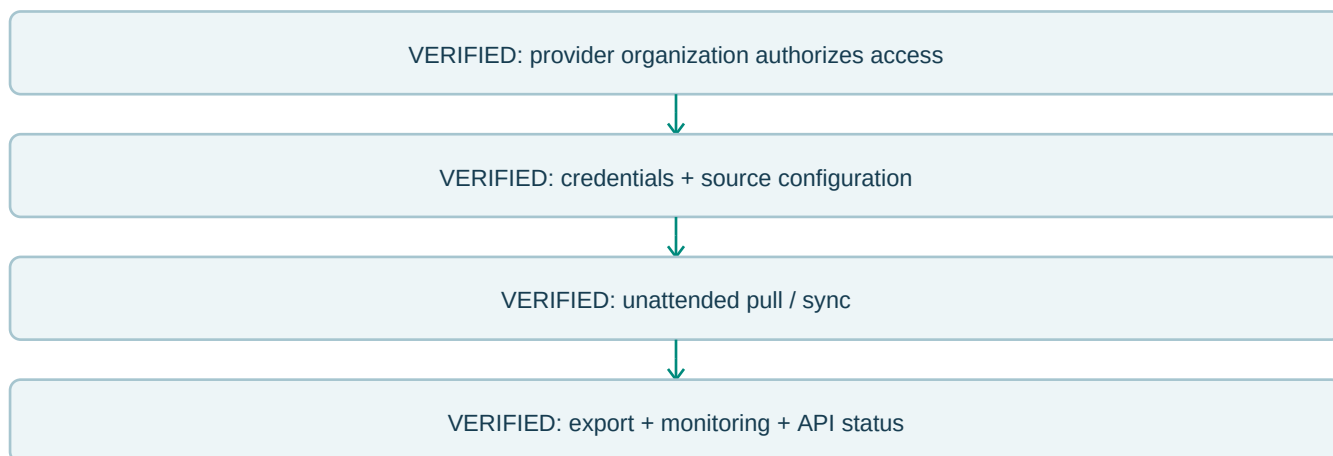
Sources [29][33][34]. Session completion can reflect success or failure; inspect result rather than assuming usable records.

For our design, retain the link between local patient identity and each source patient identifier. Do not infer a global patient identity from name/date of birth alone. Revocation or expired access affects future retrieval, while disposition of already retained records follows the applicable policy and agreements.

09. Medblocks backend and ingestion flows

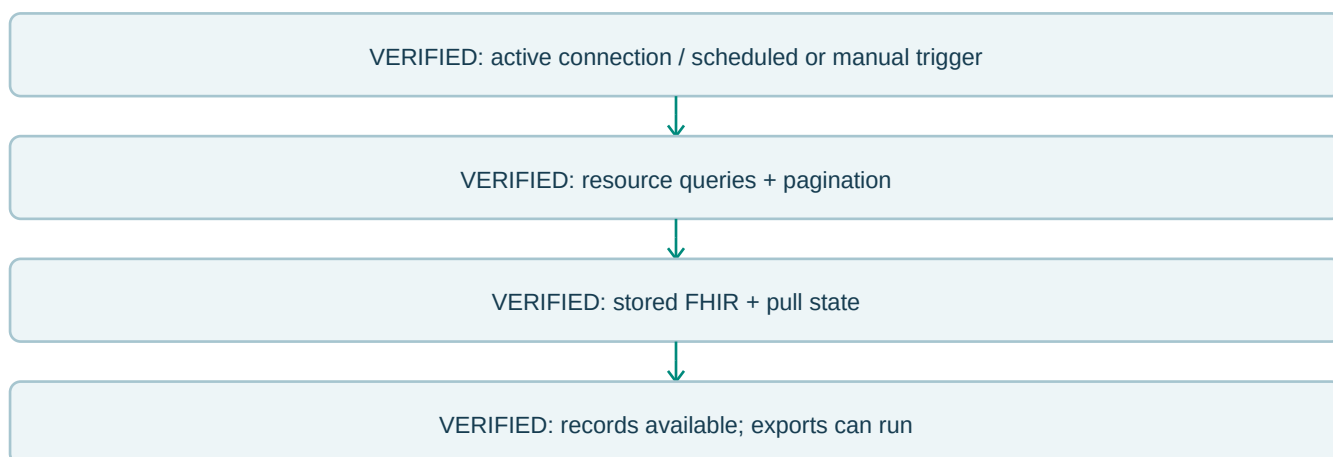
Verified public operation; no private scheduler or storage engine is asserted.

Medblocks E. Backend/system-to-system



Source [30]. Epic setup discusses SMART Backend Services and Group IDs; scope remains organization-specific.

Medblocks F. Ingestion



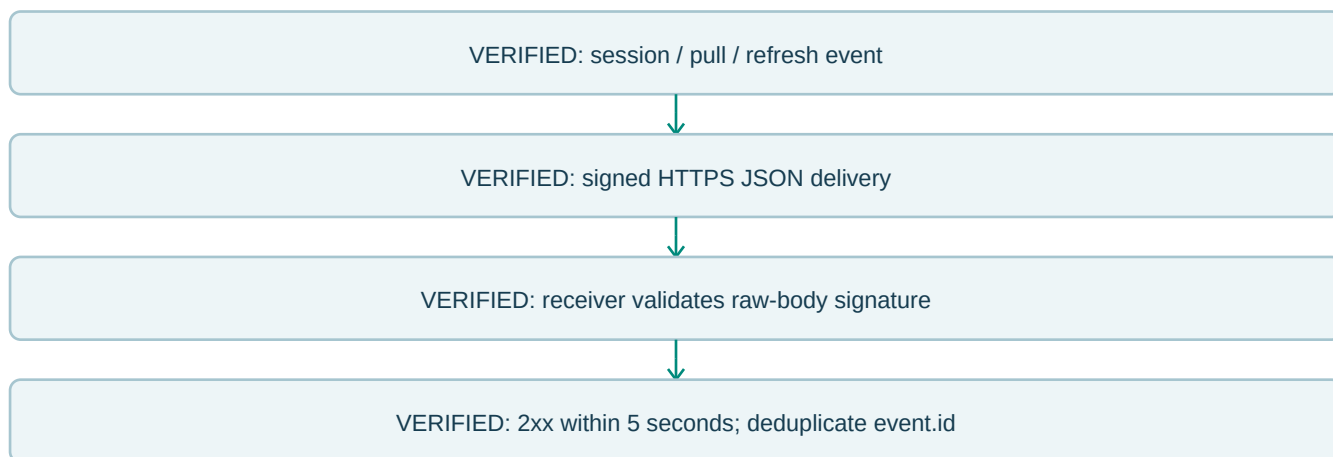
Source [33]. Token refresh failure is a reconnect condition, not a reason to keep retrying indefinitely.

Our architectural inference is that long-running retrieval needs durable jobs, credentials and checkpoints. The choice of SQS, PostgreSQL, ECS or any specific implementation later in this document is our recommendation, not a Medblocks disclosure.

10. Medblocks events, exports and open-source lessons

Verified interface behavior; reuse requires independent production review.

Medblocks G. Event/webhook flow



Source [34]. Published event families include patient_session.completed, connection.token_refresh_failed and records.sync.completed/failed.

Verified: data-out documentation describes FHIR R4 export and NDJSON object-storage destinations, configured in the dashboard rather than the public REST API. Pull completion and destination success are separate; export runs have their own results. Direct patient-record reads return stored records with source identity. [32]

Verified: the original medblocks/openFHIR repository was archived on 5 March 2026 and directs users to openFHIR/openfhir. The successor is an Apache-2.0 FHIR/openEHR mapping engine. Its README explicitly lists absent open-source production capabilities including authentication/RBAC, terminology integration and optimized performance. It is not a PA engine or a ready-to-run secure production stack. [37][38]

Recommended: borrow the separation of connection, retrieval, normalization and delivery. Use FHIR directly for this US PA MVP; introduce openEHR only for a demonstrated clinical-modeling need. If mapping is required later, evaluate the successor, maintenance model, license and security gaps rather than deploying the archived repository. The original announcement is historical context. [39]

11. Medblocks developer and operational model

Verified public interfaces; our platform adopts the design lessons without claiming internal equivalence.

The official API reference is the developer entry point. Workspace documentation describes separate Sandbox and Production workspaces, environment-specific source access, API key lifecycle and server-side bearer-key usage. The SDK/API surface covers patients, sessions, connections and operational integration. These public interfaces are not our proposed /v1 PA APIs. [\[100\]](#)[\[101\]](#)

Area	Documented fact / diligence consequence
Dashboard/admin	Workspace, API keys, connection history, source settings, export destinations and webhook endpoints are described. Verify role granularity and audit export in a demonstration. [101]
Secrets	Medblocks directs keys, source credentials, webhook secrets and destination credentials to server-side storage. This is guidance, not an independent test of its implementation. [102]
Security posture	Public materials list HIPAA, SOC 2 Type II, ISO 27001 and GDPR and BAA support; request the current scope, reports and agreements. This report does not certify these claims. [102]
Developer integration	Use documented sources/scopes and synthetic workspace first. Test authorization, pull, partial failure, record retrieval and destination failure as separate checkpoints.
Internal unknowns	No verified private cloud topology, database schema, message broker, token-encryption implementation or production performance is asserted.

Recommended parity backlog for our own connection platform: source directory, approved connection onboarding, environment isolation, grant lifecycle, checkpointed retrieval, source-aware resource reads, signed events, independently retryable exports and admin health views. The PA backlog then adds requirements, reviewed evidence, submission and decision state. Functional similarity is not evidence of identical implementation.

12. Platform vision and business architecture

Recommended | Interoperability is the foundation; reliable PA operations are the initial product.

Product capability	Customer value / accountable owner
EHR connectivity	Authorized chart context and background access; integration team
Clinical/coverage data platform	Traceable clinical facts and plan/member context; data steward
Payer connectivity	Validated request, attachment and response routes; partner operations
Prior Authorization workspace	Requirements, evidence review, submission and follow-up; PA operations
Developer platform	Versioned APIs, SDK, synthetic sandbox and event integration; developer experience
Administration / analytics	Connection health, task allocation, audit and workflow measures; customer admin

Commercial packaging hypothesis

Use a base platform subscription plus explicitly metered connectivity and PA workflows. Possible units are active connections, active patients, transactions or cases; define what counts and avoid charging for retries caused by our defects. Enterprise terms may include isolation, support and service commitments. These are proposed models, not vendor prices.

Do not sell raw PHI monetization as the business model. Contract for the customer's authorized use case and approved subprocessors. Provider groups/hospitals are the MVP buyers; healthtech startups, RCM firms, care-management platforms and healthcare SaaS are later API customers. Payers are a possible adjacent market with separate clinical and regulatory requirements.

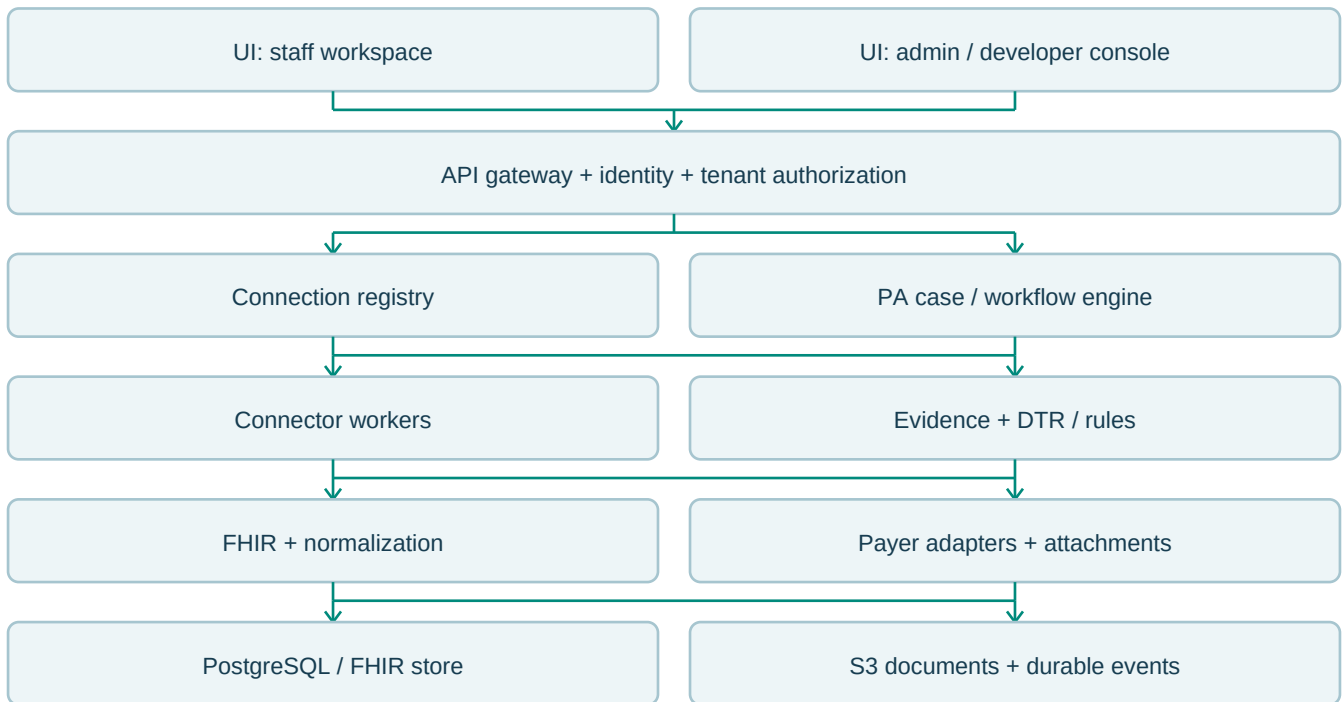
Operating model

Provider signs off clinical content; our operations team owns connector health and technical reconciliation; partner owns transport/UM services in contract; payer owns decision; customer success owns enrollment and training. Publish a responsibility matrix with explicit handoff criteria so no pending case is ownerless.

13. Target technical architecture

Recommended | Logical modules can begin as a modular application plus isolated workers.

Diagram 2. Logical architecture



Recommended. Audit, consent/purpose checks, security and observability apply across every row. Functional modules do not require separate microservices on day one.

Use a TypeScript API/UI and Java HAPI FHIR service as one practical option. Team skills can justify another application language; keep FHIR and external contracts stable. Start with a durable PostgreSQL state machine and outbox, plus asynchronous workers. Adopt a specialized workflow engine only if timers, compensation and operational visibility exceed this manageable baseline.

Keep the connection control plane separate from clinical data processing. Source credentials stay server-side. A provider-facing app can launch in the EHR while workers retrieve documents and coordinate payer responses independently of browser lifetime. No PHI should depend on a clinician leaving a tab open.

API boundaries

Our /v1 business API owns connections and PA cases. /fhir/R4 exposes only supported resource interactions through an authorization layer. Partner-facing CRD/DTR/PAS adapters implement negotiated standard contracts. Do not advertise the business API as a PAS endpoint or conflate our internal states with FHIR resource status codes.

14. Platform component inventory: access and data

Recommended | Explicit ownership for the requested foundation capabilities

Components	Design responsibility
API gateway	Version routing, request IDs, size limits, authentication handoff and rate limits; no clinical decision logic.
Authentication / authorization services	Federated staff identity, OAuth clients, RBAC plus patient/tenant/purpose ABAC; centralized deny decisions.
Tenant / organization management	Customer boundary, provider facilities, agreements, feature flags and membership; never infer tenant from submitted JSON.
Provider / patient identity	NPI and local provider IDs; source-namespaced patient IDs, verified crosswalks and uncertain-match queue.
Connection management / connector framework	Endpoint, supported capabilities, grant reference, environment, credentials reference, health and mapping version.
EHR / payer / HIE connectors	Separate adapters and authorization relationships; common error taxonomy and route ledger.
SMART / OAuth	EHR context launch and system access use different flows; validated issuer/audience and scoped tokens.
FHIR server / canonical model	Versioned source-aware clinical exchange resources; durable business entities for cases, attempts and policies.
Mapping / terminology service	Profile and semantic validation, unit conversion, versioned code mapping and provenance.
Document service	Secure ingest, malware check, metadata, hashes, versioned storage and authorized download.

Relationship test: tenant is a customer security boundary; organization is a business actor inside or outside that boundary. One tenant can contain multiple facilities, but one provider participating in several tenants must not create a shared credential or implicit data-sharing path.

15. Platform component inventory: PA and operations

Recommended | Do not omit the operational functions that make automation dependable.

Components	Design responsibility
PA engine / workflow engine	Case state, submission snapshot, tasks, deadlines, amendment and appeal handoff; durable transitions.
Rules / clinical criteria engine	Versioned administrative routing and licensed payer criteria evaluation; separate rules from clinical judgment.
Questionnaire / DTR handling	Package versions, supported CQL/ELM, prefill, missing answers, staff review and QuestionnaireResponse.
Attachment handling	Payer-required MIME/size/association, immutable request linkage and acknowledgment.
Claims / coverage data	Coverage provenance and effective dates; EOB/claims can inform history but are not a complete live chart.
Queue / jobs / webhooks / events	At-least-once work, outbox/inbox, replay, deduplication and signed delivery; no tokens in messages.
Notifications / tasks	Minimal-content alerts directing authenticated users to assigned work; clinical detail stays inside PHI boundary.
Audit / consent / security	Access and mutation trail, purpose/consent policy, security response and export controls.
Observability / monitoring	Trace IDs, latency, queue age, route health and anomalies without clinical payloads in ordinary logs.
Admin / developer portals / SDKs	Onboarding, scopes, route capability, documentation, synthetic fixtures, support and safe replay.
Warehouse / analytics	Later: purpose-limited operational marts; approved de-identification/aggregation where possible, not unrestricted PHI replication.

Recommended deployment simplicity: group the gateway-facing business modules initially; isolate connectors, document scanning and untrusted clinical-rule evaluation as workers. Split services when scale, security boundaries or team ownership justify it, rather than to satisfy a diagram.

16. EHR connectivity comparison

Verified public capability categories; production availability and exact resources need partner validation.

EHR	Public developer surfaces	Constraints / onboarding
Epic [56]	FHIR/SMART user-facing and backend OAuth; public sandbox documentation.	Customer environment, app registration, scopes and resource operations vary. Backend documentation notes differences; verify current JWK/client requirements.
Oracle Health / Cerner [57][58]	Millennium R4 APIs and authorization framework; developer program and testing entry points.	Separate patient, clinician and system app registration. Confirm tenant endpoints, permitted scopes and supported write operations.
athenahealth [59][60]	athenaOne FHIR/CDS Hooks material; athenaPractice/athenaFlow have separate guides and sandbox.	Do not use one product's auth contract for another. Service-grant documentation requires reconciliation with modern OAuth security policy.
eClinicalWorks [61]	Official site links FHIR, provider-facing SMART and bulk/backend developer portal.	Detailed portal was not retrievable in this review. Exact R4 profile, sandbox privileges, scopes and production approval remain validation items.
MEDITECH [62][63]	Greenfield developer environment, US Core R4 patient access and SMART-oriented integration.	Patient view-only APIs do not establish arbitrary writeback. Confirm Expanse/product version, app approval and system-access entitlement.

Recommended common onboarding artifact: endpoint + environment; CapabilityStatement; SMART configuration; client registration; redirect/JWK configuration; patient/provider context; required scopes; supported resource/search/write operations; pagination limits; contractual rights; production sponsor; support contacts. Test clinical notes, units, dates and identifiers using each EHR's actual representation.

Security conflict to resolve: an athenaPractice/athenaFlow guide describes a password-credential service flow. RFC 9700 says the resource-owner-password grant must not be used. Do not adopt that source-specific statement as our design standard; request a supported alternative or a formally reviewed exception before connecting. [60][46]

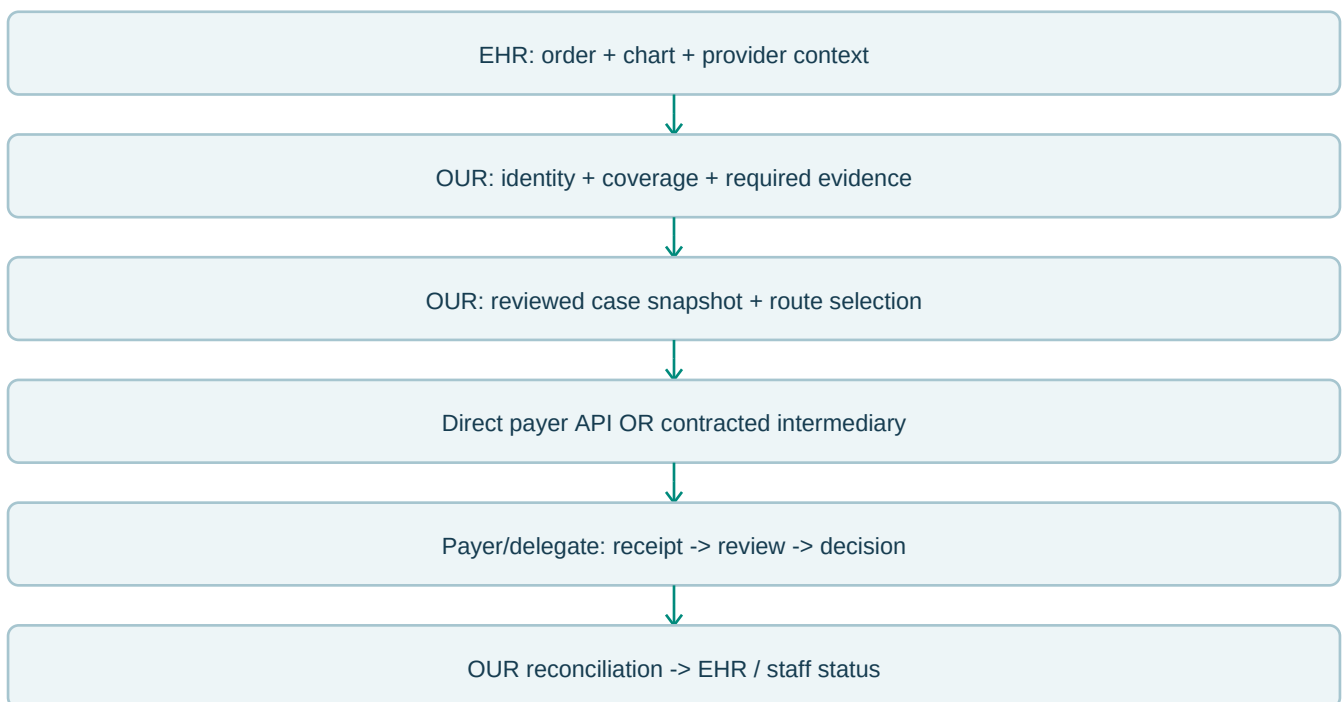
17. Payer connectivity and exchange directions

Verified examples demonstrate why a single generic payer connector is insufficient.

Category / example	Evidence and architectural consequence
Medicare / CMS	Blue Button supplies patient-authorized claims data and a synthetic sandbox. It is not evidence of a medical PA submission API. Medicare FFS program/MAC workflows must be scoped separately. [64]
Medicaid / CHIP	CMS rule includes state FFS and managed-care categories with different implementation timing. Select a named state/program and delegated plan; national uniformity is not assumed. [01]
National commercial: UHC	Provider portal supports PA/notification; public page advertises API status checks. Do not infer every submission/attachment operation from status access. [65]
National commercial: Aetna	Developer portal advertises FHIR R4, SMART/OAuth and multiple roles. Establish plan-specific PA entitlement and actual endpoint readiness separately. [66]
Blue Cross NC	Current page marks Provider Access and PA as Coming 2027. Existing patient/other APIs do not establish those future capabilities as live. [67]

Provider -> payer sends request/evidence. Payer -> provider returns receipt, information needs and determination. Patient -> payer data access retrieves the member's permitted data. EHR -> payer is the provider workflow's technical path. Intermediary -> payer transports/transforms within its agreements. These are distinct API products, scopes and trust relationships.

Diagram 4. EHR to platform to payer



Recommended. A fallback channel must keep the same case, accountability and evidence trail.

18. FHIR, profiles and exchange standards

Industry-standard contracts; versions below are an intentional baseline, not a claim that all are newest.

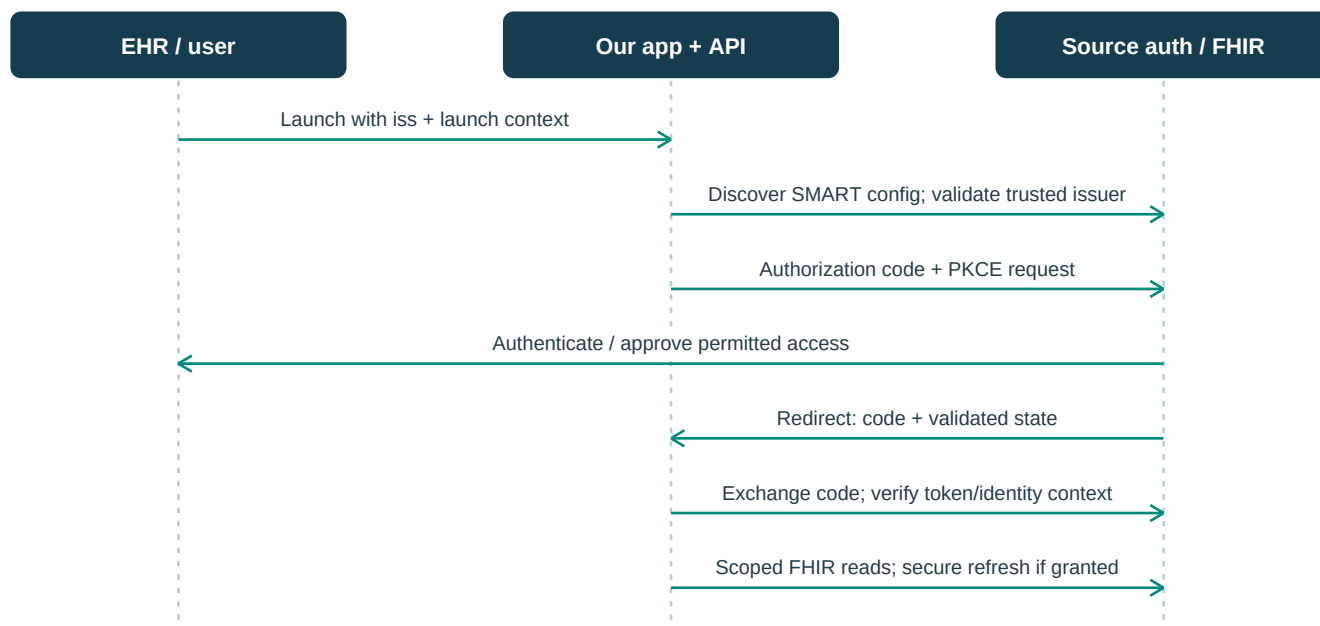
Standard	Recommended use / version discipline
FHIR R4 / R4B / R5	Use R4 4.0.1 initially for partner compatibility. R4B 4.3.0 and R5 5.0.0 require explicit conversion/testing. HL7 directory lists R5 as published and R6 snapshots/ballots as work in progress. [40]
USCDI / US Core	USCDI defines data classes/elements; US Core profiles their FHIR exchange. Certification baseline USCDI v3 begins Jan 2026 under HTI-1. Negotiate US Core, e.g. 6.1.0; its page now links a newer 9.0.0. [41] [42] [43]
SMART / OAuth / OIDC	SMART profiles launch and delegated access; OAuth grants API access; OIDC conveys authenticated identity. Pin supported versions. [44] [46] [47]
Bulk FHIR	Cohort/background exports use asynchronous jobs and NDJSON, not a synchronous all-patients request. Optional for MVP. [48]
Subscriptions / webhooks	FHIR subscriptions are version-specific protocol contracts; our webhooks are business events. Agree the PAS-compatible notification pattern. [49] [72]
HL7 v2 / C-CDA	Legacy event messages and clinical documents require source-specific mapping and original retention. C-CDA is not a FHIR JSON resource. [50] [103]
DocumentReference	Indexes document metadata; binary contents may live in secured object storage. [51]
Terminology	Use versioned CodeSystem/ValueSet/ConceptMap with validation and translation. [52]

Recommended version manifest: FHIR 4.0.1; SMART 2.2.0 where partner-supported; CRD 2.2.1, DTR 2.2.0, PAS 2.2.1 for the reference lab. Resolve their package dependencies, CDS Hooks, HREx, US Core, SDC and CDex as a compatible set. Regulatory recommendations and the exact releases accepted by a partner are different inputs. [\[69\]](#)[\[70\]](#)[\[72\]](#)

19. SMART authorization and connection security

Industry-standard flow with recommended platform controls

Diagram 5. SMART on FHIR authorization



Industry-standard basis [44][46][47]. Diagram abbreviates browser redirects; app holds tokens server-side in the recommended BFF design.

For patient/clinician launch, bind state and PKCE to a short-lived browser session, allowlist redirect URIs and endpoints, validate issuer/audience and ID-token signature/nonce where applicable, and bind returned patient context to the case. A user identity alone does not grant access to every patient.

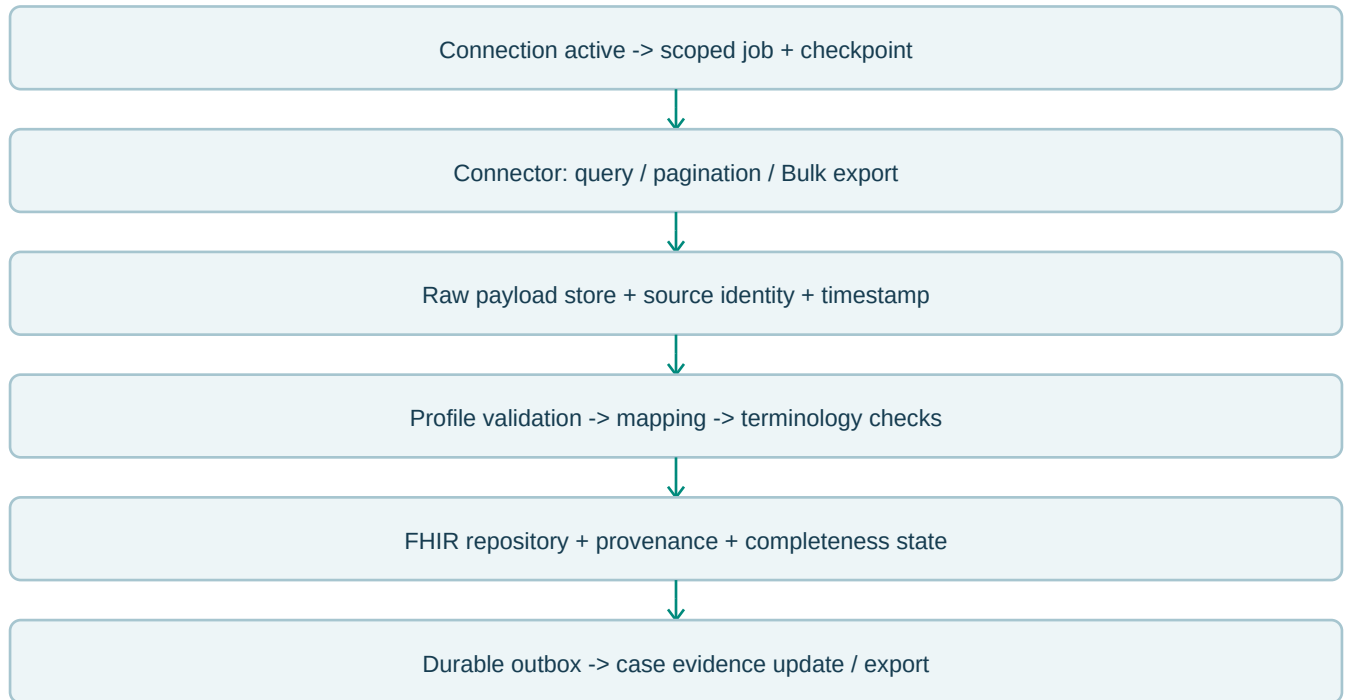
Backend access is a separate preauthorized system grant. Prefer SMART Backend Services with asymmetric client authentication and short-lived assertions; securely register public keys and restrict system scopes to the approved cohort/organization. Do not rely on a patient refresh token to substitute for provider system access. [45]

Recommended: secrets in managed vault, rotating keys, single-flight token refresh per connection, encrypted token cache and explicit revoked/expired states. Avoid token-bearing URLs, browser localStorage credentials, arbitrary FHIR base URLs and user-supplied metadata endpoints that enable SSRF. Consent and legal purpose remain policy checks beyond OAuth.

20. Ingestion and clinical data quality

Recommended | Access granted, data retrieved and data fit for PA are separate milestones.

Diagram 6. FHIR ingestion



Failures go to quarantine or retry according to error type. A partial pull never silently becomes a complete clinical record.

Deduplicate by tenant + source endpoint + resource type/id + version/hash. Keep source lastUpdated and clinical effective time separately from ingestion time. Follow server pagination links through an allowlisted origin; checkpoint at committed pages. Use overlap windows for incremental queries and deduplicate replay. Process deletions/entered-in-error updates according to source semantics.

Normalize units only when dimensionally valid and clinically approved. Preserve original values/codes and mapping version. A missing Observation is unknown, not a normal result. A medication order is not proof of dispensing or adherence. Document extraction is a candidate fact with page/source evidence until reviewed.

Recommended ingestion states: queued, running, partial, complete, failed, access_revoked. Completeness is scoped to requested types, time range and source capability. Set a PA evidence freshness requirement by policy and clinical workflow; do not use one global freshness number.

21. HIE and network strategy

Verified frameworks provide record exchange; PA transaction rights are a separate question.

TEFCA defines a national trust and exchange framework with QHINs and permitted exchange purposes. Carequality provides legal, policy, technical and governance arrangements across networks. CommonWell offers network services and onboarding, including record-location capabilities. None of these statements proves that a particular patient record or payer PA endpoint is available to this project. [\[53\]](#)[\[54\]](#)[\[55\]](#)

Decision	Recommended approach
MVP access	Use the sponsored EHR and payer route first; avoid making national network onboarding the critical path.
Future network participation	Partner with an eligible implementer/QHIN pathway appropriate to the customer and purpose; review agreements and current technical framework.
Patient matching	Keep match evidence and confidence; uncertain matches require review. Never merge cross-network identities merely by demographic similarity.
Documents	Retain source C-CDA/PDF, document identifiers and provenance. Index in DocumentReference; extract only relevant facts.
Purpose controls	Assert the true purpose and user/organization relationship; do not label payer/payment work as treatment to gain access.
Limitations	Availability, matching, permitted purpose, patient choices and source content vary; retries cannot overcome a missing legal entitlement.

Other useful mechanisms can include IHE document exchange profiles, Direct secure messaging or regional HIE feeds where contracted. These are optional integration patterns, not MVP commitments. Validate the exact interface before implementing a generic HIE connector.

22. Legacy interfaces and normalization boundaries

Industry-standard source formats; recommended adapter behavior

HL7 v2-to-FHIR guidance includes mappings for patient administration, orders, observation reporting, documents and scheduling. Treat these as mapping guidance, not proof that every local segment/Z-segment maps losslessly. C-CDA conveys structured clinical documents with context that must survive extraction. [\[103\]](#)[\[50\]](#)

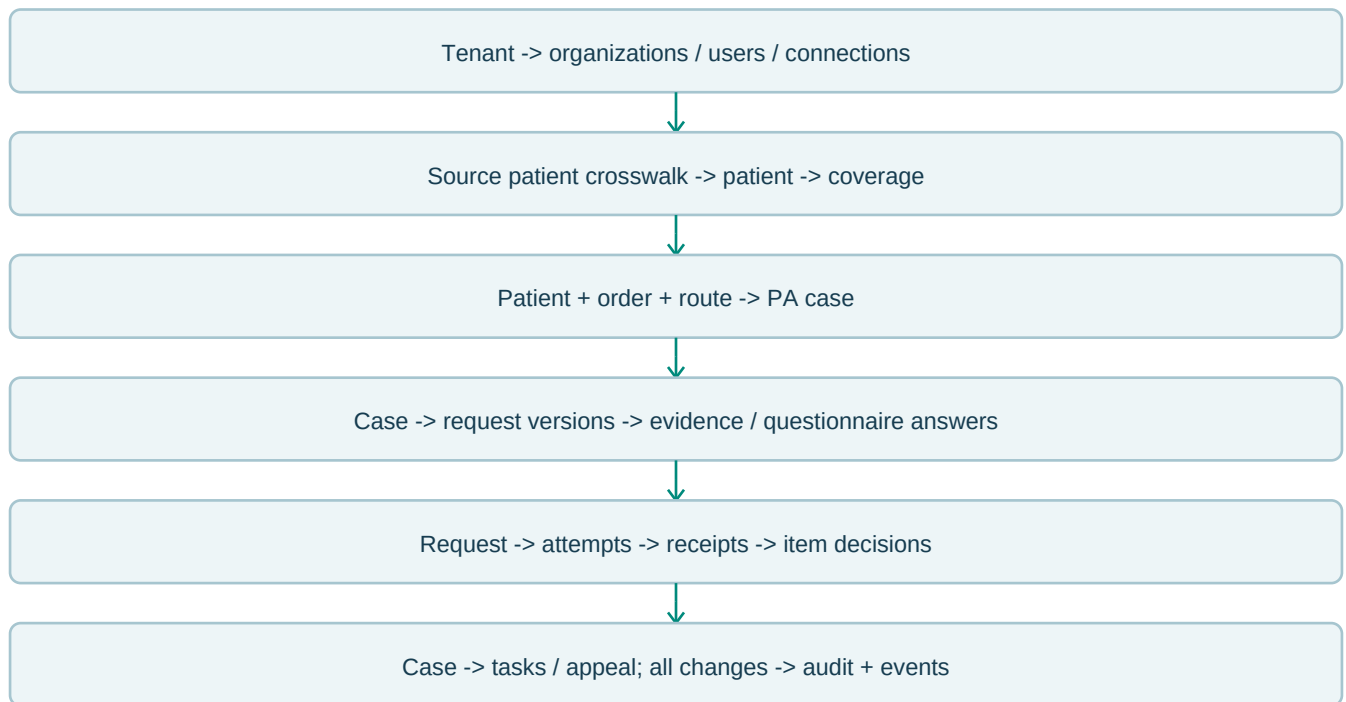
Input	Recommended handling
HL7 v2 ADT/result/order feed	Agree message version/profile and transport; authenticate the sender; retain message control ID and payload. Validate and acknowledge transport separately from downstream PA processing. Apply patient merges/corrections deliberately.
C-CDA or PDF	Store original document and provenance; index via DocumentReference. Preserve author, encounter and document date. Parse structured entries where valid; review extracted narrative facts.
FHIR search/page	Validate source/profile and security context; record stable source ID/version; handle partial results and pagination without losing references.
Bulk export	Authorize cohort; persist job/content-location; follow async completion and approved file URLs; validate NDJSON and checkpoint imports. [48]
DocumentReference/Binary	Reference metadata and binary permissions both need checks. A URL is not public permission to download or redistribute the document. [51]

Recommended mapping rule: preserve source semantics first, then add canonical projections. Record mapping/version, source IDs, confidence and exclusions. Route unsupported content to quarantine/review. Do not discard unrecognized fields if they can affect clinical interpretation, and do not turn absence in an incomplete feed into a negative clinical finding.

23. Data architecture: conceptual and storage model

Recommended | FHIR is the clinical exchange model; business workflow needs additional durable entities.

Conceptual data relationships



All patient/case relationships are tenant-scoped. A payer decision references the immutable request version it evaluated.

Store	Purpose and consistency boundary
PostgreSQL business database	Tenants, memberships, connection metadata, cases, immutable submission metadata, tasks, idempotency, inbox/outbox; transactionally commit state and events.
FHIR repository	Versioned source/canonical resources, profiles and clinical queries. Do not directly edit the FHIR server's internal tables.
S3 document/raw store	Encrypted documents, source payloads and immutable request snapshots. Metadata and checksum link to case/resource versions.
Secrets service	Credentials, refresh tokens and signing keys referenced by opaque IDs; no secret values in business rows.
Analytics store (later)	Purpose-limited operational metrics or approved datasets; access and retention distinct from operational care records.

Avoid dual-write assumptions: write the business transaction and outbox atomically, then project into FHIR or other stores with retry and reconciliation. A case can retain a verified evidence snapshot even if a downstream search index is temporarily unavailable. Database backups are not an event replay mechanism.

24. Data dictionary: tenancy, identity and connectivity

Recommended | C = confidential configuration; P = PHI; S = secret; retention classes are defined later.

Entity / keys and relationships	Source of truth / sensitivity / retention
Tenant: tenant_id, name, region, policy, state	Platform contract/admin; C; tenant configuration lifecycle.
Organization: tenant_id + org_id, NPI/TIN, facilities	Verified customer/provider registry and source; C, sometimes linked P; configuration.
Provider: provider_id, NPI, org memberships, source IDs	Credentialed provider directory/EHR; C/P in care links; configuration + case evidence.
Patient: patient_id, source identifiers, demographics	EHR/member assertions with provenance; P; clinical schedule.
Payer: payer_id, legal entity, plan/delegate routes	Partner registry; C; versioned configuration.
Coverage: coverage_id, patient, member ID, plan, period	Payer/eligibility source with last verified time; P; case evidence.
EHR: ehr_id, product/version, endpoint, capabilities	Partner onboarding record; C; configuration history.
Connection: connection_id, tenant/org, source, grant_ref, state	Platform plus source authorization state; C/S reference; lifecycle + security evidence.
Consent: consent_id, subject, purpose, scope, period, status	Captured/legal-source record; P; privacy-approved schedule.
Access authorization: grant_id, issuer, client, scopes, expiry	Source auth server and local policy; S reference; expiry/revocation plus audit.
FHIR resource: source/type/id/version, tenant, hash, provenance	Source EHR/payer; derived canonical copy retains linkage; P; clinical schedule.

The access authorization entity is deliberately named differently from a PA case. A tenant ID is mandatory in every protected relationship, index and uniqueness rule. Provider identifiers and plan names alone are insufficient routing keys.

25. Data dictionary: PA, evidence and operations

Recommended | Use immutable versions for anything that can affect a decision.

Entity / keys and relationships	Source of truth / sensitivity / retention
PA case: case_id, patient, coverage, order, owner, state	Platform workflow; P; case retention schedule.
PA request: request_id/version, case, snapshot_hash, attestation	Provider-reviewed snapshot; P; case schedule + hold.
Payer policy / clinical criteria: policy_id/version, plan, effective dates, license	Payer/licensed publisher; C/IP, P if case-linked; version retention.
Questionnaire: canonical URL/version, package hash, dependencies	Payer DTR artifact; C/IP; retain referenced version.
QuestionnaireResponse: response_id/version, answers, provenance	Reviewed provider answers; P; case evidence.
Supporting document / attachment: doc_id/version, hash, URI, MIME, request link	Source document/provider; P; case evidence + scan/disposition.
Decision: decision_id, request, payer reference, items, dates, units, reason	Payer/delegate response; P; immutable case evidence.
Appeal: appeal_id, original decision, deadline, grounds, receipts	Provider appeal + external authority; P; case/legal schedule.
Task: task_id, case, owner, due_at, state	Platform or correlated external Task; P; case schedule.
Webhook / event: endpoint_id, secret_ref; event_id, sequence, refs	Platform event log; C/P metadata; bounded delivery/replay.
Audit log: actor, action, tenant, purpose, target, time, outcome	Append-only platform audit; P-sensitive; compliance schedule.
Terminology mapping: source/target system+version+code, relation, reviewer	Terminology service/approved mapping; C/IP; retain referenced versions.

Add submission_attempt, receipt, outbox_event, inbox_event, idempotency_record and connector_checkpoint tables. These separate transport attempts from clinical request versions and make recovery possible without silently duplicating care requests.

26. Example schema and FHIR resources

Recommended examples | Synthetic | Not a complete PAS-conformant submission bundle

```
CREATE TABLE pa_case (  
  tenant_id uuid NOT NULL, case_id uuid NOT NULL,  
  patient_id uuid NOT NULL, coverage_id uuid NOT NULL,  
  route_id uuid NOT NULL, state text NOT NULL,  
  version bigint NOT NULL DEFAULT 1,  
  PRIMARY KEY (tenant_id, case_id)  
);  
CREATE TABLE pa_request (  
  tenant_id uuid NOT NULL, request_id uuid NOT NULL,  
  case_id uuid NOT NULL, revision int NOT NULL,  
  snapshot_uri text NOT NULL, sha256 text NOT NULL,  
  reviewed_by uuid NOT NULL, reviewed_at timestamptz NOT NULL,  
  PRIMARY KEY (tenant_id, request_id),  
  UNIQUE (tenant_id, case_id, revision),  
  FOREIGN KEY (tenant_id, case_id)  
    REFERENCES pa_case(tenant_id, case_id)  
);  
-- Add composite FKs to patient/coverage/route tables,  
-- RLS, privileges, state constraints and outbox transaction.
```

```
{  
  "resourceType": "ServiceRequest", "id": "synthetic-order-1",  
  "status": "active", "intent": "order",  
  "subject": {"reference": "Patient/synthetic-patient-1"},  
  "code": {"text": "SYNTHETIC imaging order"},  
  "requester": {"reference": "Practitioner/synthetic-clinician-1"}  
}
```

This base-R4 example illustrates intent and references, not a US Core/PAS profile pass. A production PA package requires the selected IG profiles, coded services, coverage, organizations, identifiers and supporting evidence. Do not send this illustrative object to a payer.

FHIR roles: Patient/Practitioner/Organization represent actors; Coverage represents insurance context; Encounter and ServiceRequest identify context/order. Condition, Observation, DiagnosticReport and Procedure supply evidence where relevant. MedicationRequest belongs in a drug workflow when appropriate; it is not interchangeable with a pharmacy NCPDP message.

27. Synthetic resource and API examples

Recommended illustrative JSON; syntax-checked only, not profile/conformance validated.

```
{
  "resourceType": "Patient", "id": "synthetic-patient-1",
  "identifier": [{"system": "https://example.org/synthetic-id",
    "value": "SYN-001"}],
  "name": [{"family": "Synthetic", "given": ["Alex"]}]}
}
```

```
{
  "resourceType": "Coverage", "id": "synthetic-coverage-1",
  "status": "active",
  "beneficiary": {"reference": "Patient/synthetic-patient-1"},
  "payor": [{"reference": "Organization/synthetic-payer-1"}]}
}
```

```
{
  "resourceType": "QuestionnaireResponse", "id": "synthetic-qr-1",
  "questionnaire": "https://example.org/Questionnaire/test|1.0",
  "status": "completed",
  "subject": {"reference": "Patient/synthetic-patient-1"},
  "item": [{"linkId": "evidence-reviewed",
    "answer": [{"valueBoolean": true}]}]}
}
```

```
POST /v1/prior-authorizations/pa_syn_1/submit
Idempotency-Key: synthetic-submit-001
If-Match: "2"
{"reviewed_snapshot_id": "snap_syn_1"}
202: {"operation_id": "op_syn_1", "state": "queued",
  "payer_receipt": null, "clinical_decision": null}
```

Referenced Organization and Questionnaire definitions must exist in a real test fixture. The artificial evidence-reviewed question is not payer medical policy. completed QuestionnaireResponse is not a payer approval. The 202 response confirms only our queued work; receipt and decision are populated after validated external responses.

28. Terminology architecture

Industry-standard vocabularies; recommended mapping governance

Vocabulary	Role and design constraint
SNOMED CT	Clinical concepts; verify licensing and permitted distribution by territory. [84]
LOINC	Observation/document concepts; preserve code and method/context. Available under its license, not unrestricted public-domain content. [85]
RxNorm	Normalized drug concepts; strength/form/ingredient distinctions matter. Mapping does not automatically determine a billable product. [86]
ICD-10-CM	US diagnosis classification; preserve release/effective date. Do not confuse with ICD-10-PCS inpatient procedure coding. [87][88]
CPT / HCPCS	Procedure/service and supplies coding; CPT is AMA copyrighted. Review licensing; map modifiers, units and site separately. [88]
NDC	Drug product/package identification; preserve representation and effective version. Directory presence is not FDA approval. [89]
UCUM / local codes	Use standardized units where appropriate; retain local code + system + version and a reviewed mapping.

Recommended service: validate-code, lookup, expand and translate over a curated, licensed terminology set. Store CodeSystem/ValueSet/ConceptMap versions and immutable release manifests. A ConceptMap relationship may be broader/narrower, not equivalent. Reject ambiguous unit/code conversions from automatic PA answers. [52]

Example: a payer criterion may ask for a lab threshold within a date range. The pipeline must resolve the test concept, specimen/method if material, unit, clinical time and qualifying result status before comparison. Preserve the raw observation and the rule evaluation inputs. Do not let an AI-generated code or negation become an attested clinical fact without review.

Policy versus terminology

A valid code does not prove coverage. Payer policy adds plan, indication, time, prior treatment, site and documentation conditions. License and version clinical criteria separately, with effective dates and change review. Do not scrape a payer document and assume permission to redistribute or execute it as definitive policy.

29. Prior Authorization business workflow

Level 2 | Medical-service workflow; each handoff has an accountable actor.

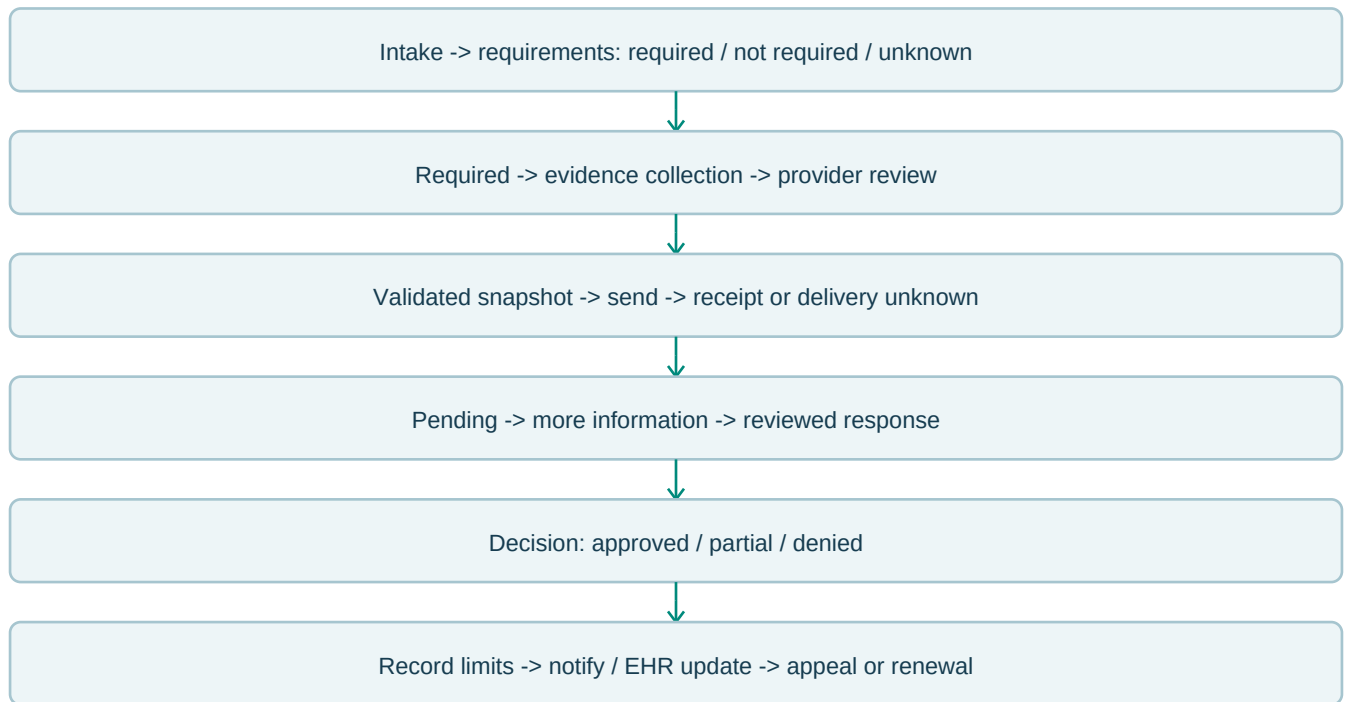
Step	Owner / required result
1 Patient and order	Provider/EHR: identify patient, requested service, ordering/rendering providers and intended date.
2 Coverage discovery	Platform + provider: verify member/plan, benefit and delegate route; Coverage alone may be stale.
3 Is authorization required?	Payer supplies authoritative requirements; platform retrieves and records result, including unknown/no-PA.
4 Clinical requirements	Payer owns criteria; platform retrieves supported questionnaire/policy; staff resolve missing or ambiguous requirements.
5 Clinical facts and documents	EHR supplies records; interoperability layer retrieves/maps; provider corrects and attests.
6 Validate and build	PA engine verifies completeness, identity, coding, dates, attachments and selected protocol.
7 Submit and acknowledge	Platform sends reviewed snapshot; payer/intermediary provides technical receipt. Receipt is not approval.
8 Review / more information	Payer/delegate reviews; PA engine assigns information requests; provider responds with linked evidence.
9 Decision	Payer approves, denies or partially approves by item; platform records dates, units, reason and reference.
10 Close and notify	Platform updates permitted EHR workflow and staff; provider communicates implications to patient.
11 Appeal / amend / renew	Provider decides action, payer defines route/deadline; engine tracks tasks and receipt without assuming PAS covers all appeal semantics.

Urgency is an explicit clinical/business designation, not a technical priority setting invented to accelerate processing. A partially approved request needs item-level representation; more-information and pending are not denials. Expiry or a changed order can require amendment/new authorization even after approval.

30. PA lifecycle and exception flow

Recommended state machine; map external states without losing original meaning.

Diagram 7. Prior Authorization workflow



No-PA exits with an evidence record. Unknown requirements or uncertain delivery create tasks; they never silently advance to approved.

Persist transitions with expected case version, actor, timestamp, reason and triggering external event. Separate case state from transport state, document availability and clinical determination. A final response can arrive after an operator has started manual follow-up; reconciliation must prevent conflicting duplicate actions.

Medical versus pharmacy

Medical-service PA usually begins with a provider order and service/diagnosis evidence. Pharmacy-benefit ePA commonly uses NCPDP SCRIPT through PBM/network workflows, including prescriber or pharmacy triggers. Medical-benefit drugs can follow medical routes; benefit and payer contract, not the mere presence of MedicationRequest, select the adapter. [\[18\]\[21\]](#)

Appeals

Create an appeal entity linked to the original decision and evidence, with deadline, submission route, owner and receipt. The original decision remains immutable. Support staff-assisted appeal packaging first; do not claim standard PAS implementation alone automates peer-to-peer review, formal appeal or external review. Separate resubmission, correction and appeal in UI and audit.

31. CMS requirements and version baseline

Verified regulatory context as of 30 September 2026; applicability must be mapped to the actual product/plan.

CMS-0057-F includes specified Medicare Advantage, Medicaid/CHIP and FFE QHP payer categories. Generally, operational provisions start in 2026 and API provisions in 2027 with program-specific dates. PA provisions in this rule exclude drugs. The decision timeframes include 72 hours for expedited and seven calendar days for standard requests for specified impacted payers; FFE QHP issuers are excepted from those decision timeframes. [01]

Current CMS overview still lists CMS-0062-P for drug-related interoperability/PA as proposed. HHS also publishes a proposed HIPAA Security Rule update separately from its currently effective summary. Neither proposal is treated as enacted implementation law in this design. [02][76][77]

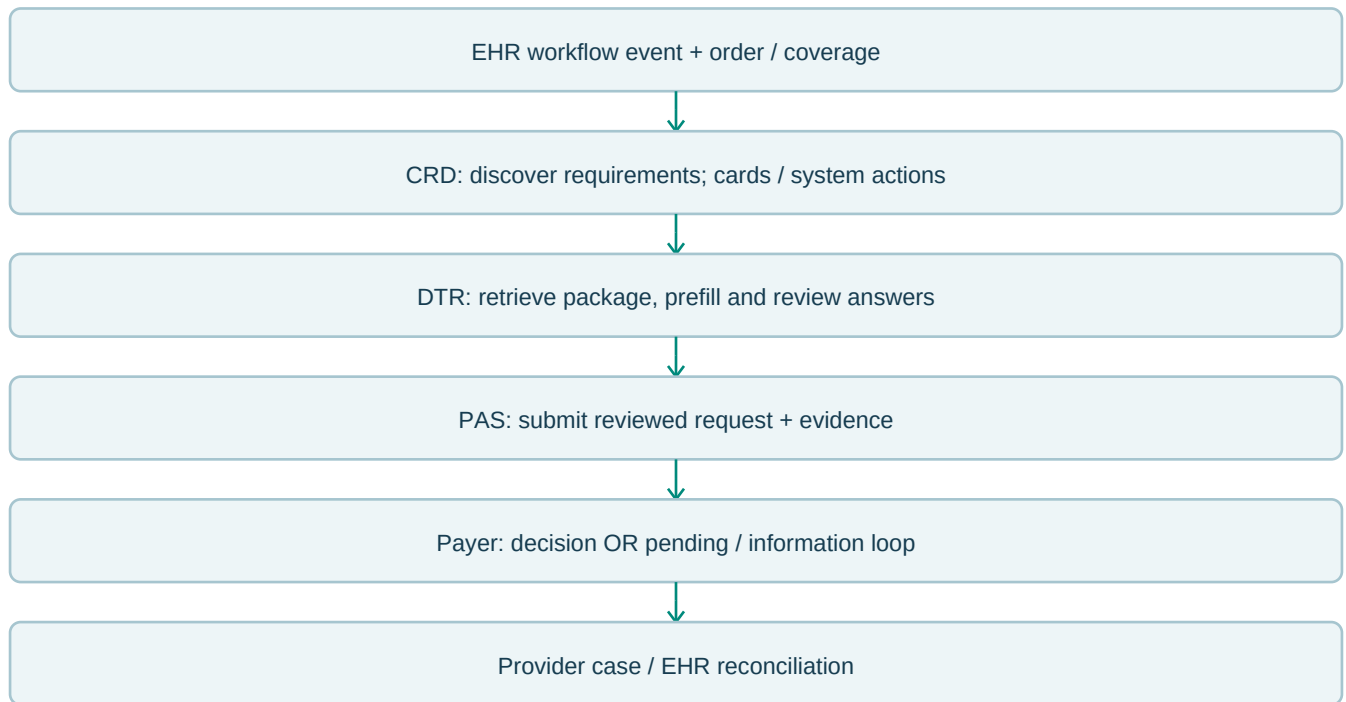
CMS recommends Da Vinci guides for the workflow; distinguish recommended implementation guides from required standards and the exact release accepted by a partner. CMS describes scoped enforcement discretion permitting qualifying all-FHIR PA exchange without X12 278; this is not a universal repeal of X12 transaction obligations. [01][68]

Control	Recommended implementation
Applicability register	Legal/compliance records payer category, benefit, jurisdiction, obligation and effective date; product behavior is driven by reviewed configuration.
Deadline engine	Store receipt time, urgency, program-specific clock/extension rules and evidence; alert staff before the applicable deadline.
Denial/decision evidence	Retain original response and specific reason, coverage limits and communication record.
Standards manifest	Pin FHIR/profiles/IG packages, validator versions and route contracts; do not deploy arbitrary latest builds.
Change management	Quarterly and pre-release review of official rules and payer notices; emergency changes have an accountable owner.

32. CRD, DTR and PAS relationship

Industry-standard roles; our platform acts as a provider-side coordinator.

Diagram 8. Da Vinci burden-reduction relationship



Sources [\[69\]](#)[\[70\]](#)[\[72\]](#). This is a common path, not a requirement to call all three for every case. Some CRD responses can convey satisfied authorization; preserve their provenance.

Guide	Trigger / inputs / outputs
CRD 2.2.1	Clinical hook, e.g. order workflow; context/prefetch/coverage -> coverage requirements and supported actions. Typically an interactive response. [69]
DTR 2.2.0	Documentation required; order, coverage and questionnaire context -> versioned package and completed QuestionnaireResponse. Human work may span sessions. [70] [71]
PAS 2.2.1	Reviewed request ready; profiled Claim-led Bundle -> response Bundle with ClaimResponse and follow-up workflow. Decision may be immediate or later. [72] [73] [74]

Unsupported partner path: retain requirements as unknown, use contracted alternatives and explicit staff work. A homegrown form can serve the product but is not automatically DTR-conformant. A generic Claim API can serve a route but is not automatically PAS. Never translate a missing capability into no-PA-needed.

33. CRD and DTR implementation contracts

Industry-standard basis with recommended controls and storage

CRD client/coordinator

Discover contracted CDS services and supported hooks; trigger from the EHR interaction. Build hook context/prefetch and narrowly scoped FHIR access when required. Correlate hookInstance/order/coverage with the local case; persist returned coverage information and timestamps. Display the required user feedback and handle system actions according to the selected release. A slow/unavailable CRD service should produce an actionable unknown state. [69]

DTR app or native capability

Carry payer, patient, order, coverage and questionnaire context from the workflow. Obtain the questionnaire package with the selected operation contract: the response is Parameters containing package Bundle content, not just a bare Questionnaire. Pin Questionnaire, Library/ELM and terminology dependencies. [70][71]

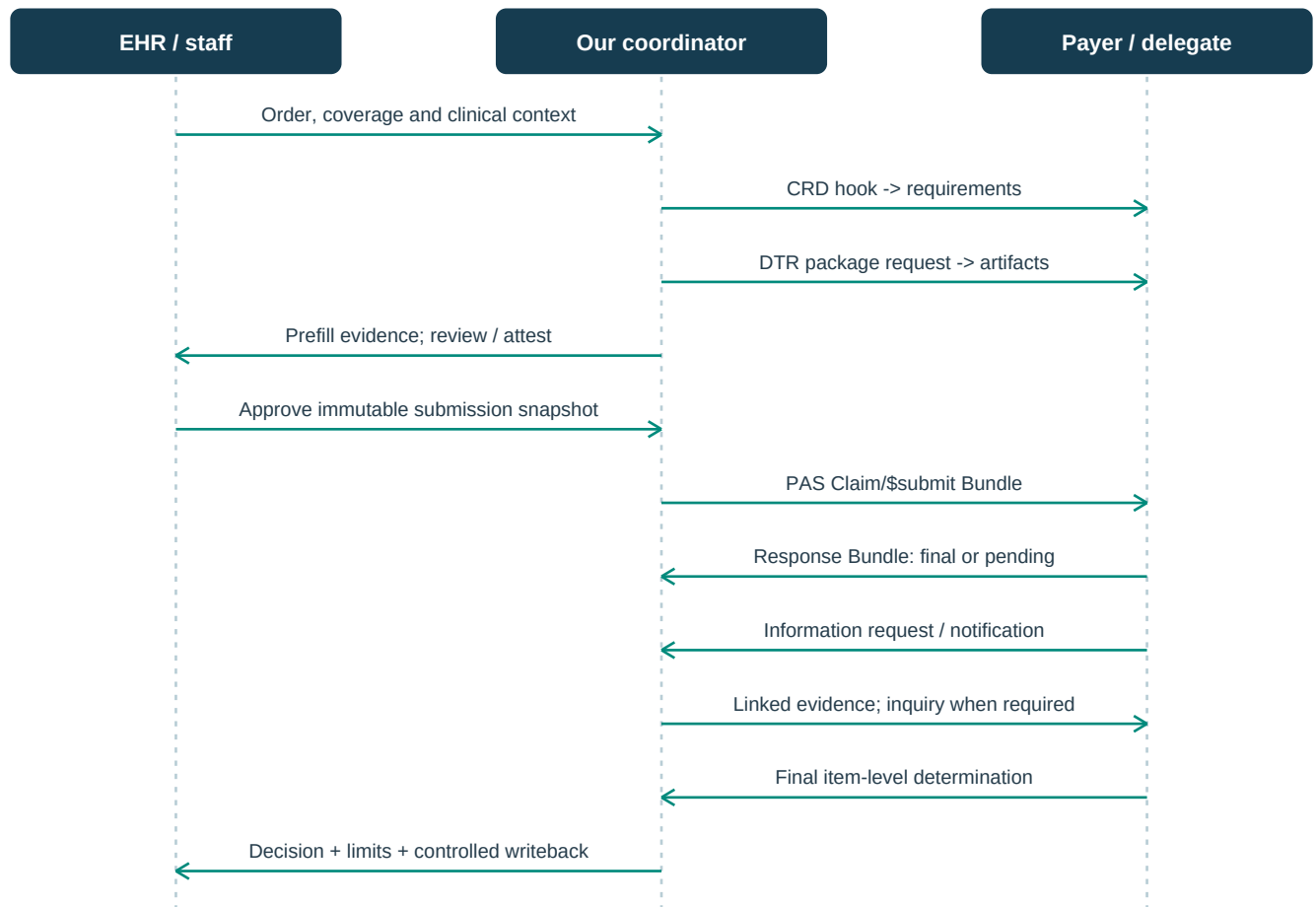
Recommended: evaluate supported expressions in a constrained runtime with CPU/time/network limits. Prefill only permitted source data; record source resource/version for each answer. Missing, conflicting or unavailable facts remain visible. Staff review/attest before a response becomes submission evidence. Store response versions and resume state; do not re-run a new policy version silently mid-case.

Failure	Handling
No hook or no payer service	Manual requirements task; no fabricated CRD result.
Expired FHIR token	Reauthorize/refresh according to grant; bound retries and preserve case.
Untrusted questionnaire URL	Allowlist source, validate package/signature if contracted; block SSRF.
Unsupported CQL/operator/value set	Explicit incomplete state and clinician/staff task, not guessed answer.
Changed questionnaire	Version comparison, revalidation and review; preserve prior submitted evidence.

34. Medical PA sequence and PAS behavior

Industry-standard messages; recommended durable case handling

Diagram 9. Medical PA sequence



Sources [69]-[75]. Repeated arrows abbreviate request/response pairs. Notification is a trigger to reconcile, not authority to overwrite state blindly.

PAS submission uses the specified Claim/\$submit operation and profiled request/response Bundles. Inquiry uses Claim/\$inquire. Preserve external identifiers and item correlation. A FHIR processing OperationOutcome is not a clinical denial; ClaimResponse adjudication data must be interpreted using the negotiated profile and route. [72][73][74]

Additional information can use Task and CDex attachment patterns, including a requested questionnaire. The selected IG and partner contract govern linkage and completion. Decide up front who hosts subscribed endpoints, handles missed notifications and polls/reconciles outstanding cases. [75]

35. Technical PA step contracts: intake and evidence

Recommended mapping | Each row names interface, actor, data, control, event and failure behavior.

Step / interface / actor	Inputs -> outputs; persistence and controls
Intake: POST /v1/prior-authorizations EHR app -> case service	Patient, Coverage, ServiceRequest, Practitioner/Organization references -> draft case. Staff OAuth + tenant/patient policy; verify identity and route. Store case/version, emit case.created, audit case.create. Idempotency required; 422 invalid reference, 409 duplicate/conflict.
Read clinical data: FHIR search/read connector -> EHR	Patient context + scoped query -> Condition/Observation/DiagnosticReport/Procedure/Encounter and DocumentReference as needed. Source OAuth/SMART; least-privilege scopes. Store raw/version/provenance, emit evidence.updated, audit source.read. Safe read retry on transient failures; 403 stops for entitlement review.
Requirements: CRD hook coordinator -> payer	Order/coverage/context -> requirements or unknown. Contracted server authentication plus authorized data access. Store response/policy reference; requirements.checked audit/event. Bounded interactive retry; timeout creates task, not no-PA.
Documentation: DTR package + UI DTR app / staff	Package + source facts -> reviewed QuestionnaireResponse. SMART/scoped FHIR and payer credential; validate canonical versions and answer types. Store answer provenance; evidence.attested audit/event. Retry retrieval; no automatic attestation after evaluation error.
Documents: POST /documents staff/connector -> document service	Document bytes/metadata -> quarantined then clean document reference. User/service policy; MIME/size/hash/malware validation. Store encrypted content and version; document.accepted audit/event. Failed scan blocks attachment.

Common contract: authentication establishes caller; authorization checks tenant, membership, purpose, patient and action. Validation happens before any externally visible side effect. Audit captures actor/action/object/outcome and correlation ID without putting clinical narrative in general application logs.

36. Technical PA step contracts: exchange and closure

Recommended mapping | Business request, transport attempt and decision remain separate records.

Step / interface / actor	Inputs -> outputs; persistence and controls
Submit: POST /submit -> PAS \$submit reviewer / worker -> payer	Reviewed version + profile-valid Bundle -> attempt/receipt/response. Reviewer role then partner credentials; verify attestation/hash and route. Store immutable snapshot + attempts; submission.queued/sent audit/events. Timeout after send -> delivery_unknown; reconcile before resend.
Status: GET /status -> PAS \$inquire worker -> payer	External case refs -> current response. Partner-scoped credential; match patient/request/items. Store raw and normalized status, emit status.changed, audit status.reconcile. Backoff reads; preserve last-known timestamp on outage.
Respond: POST /respond -> attachment route staff/worker -> payer	Information request + reviewed answers/docs -> linked response receipt. Validate open request and evidence versions. Store submission link; information.responded audit/event. Retry only with safe idempotency/receipt reconciliation.
Decision ingestion: webhook / inquiry payer -> coordinator	Authenticated notification/response -> item decisions and tasks. Verify sender, replay window, matching IDs and sequence. Inbox dedup; append immutable response; decision.recorded audit/event. Quarantine mismatches; do not override with stale status.
Writeback / notify: approved EHR API worker -> EHR/staff	Decision summary + authorization limits -> linked EHR/task update. System grant and allowed write path; preserve response. Separate writeback job and event; safe dedup retries. PA remains decided even if EHR update fails.
Appeal: POST /appeal provider -> platform / external route	Denied item + grounds/evidence -> appeal task/receipt. Explicit authorized role and deadline. Original decision immutable; appeal.created/submitted audit/events. Route-specific transport; unsupported automated appeal stays staff-owned.

Communication can represent relevant correspondence, Task can represent a correlated work item, and Provenance can capture data lineage. Use these only where they add interoperability value. Our internal task table does not automatically implement the PAS/CDex Task profile.

37. API architecture and common contract

Recommended /v1 business API; these endpoints are our design, not Medblocks or payer APIs.

Expose OpenAPI schemas, bounded pagination and versioned event envelopes. Bearer tokens use staff OIDC or registered service clients; partner SMART credentials are stored behind connection IDs. Server-resolved tenant and policy determine access. Separate read, prepare, review, submit, admin and audit permissions.

Rule	Contract
Mutation idempotency	Require Idempotency-Key for externally significant POSTs. Scope key to tenant+client+operation; persist canonical request hash and original result. Same key/different body -> 409. Retain through maximum retry/reconciliation window.
Optimistic concurrency	Return ETag/case version; require If-Match on attestation, submit and amendments. Stale evidence -> 412/409, not silent overwrite.
Async work	202 + operation_id + status URL means work accepted by our platform, not delivered to payer. Expose technical and clinical states separately.
Errors	400 malformed; 401 invalid auth; 403 forbidden; 404 absent/not visible; 409 conflict; 412 version; 422 validation; 429 quota + Retry-After; 502/503 dependency. Error body has safe code, request_id, retryable and field issues.
Retries	Retry safe reads with jitter; honor Retry-After. Never auto-repeat uncertain payer sends without reconciliation. Non-retryable errors create tasks.
Audit	Every PHI read and consequential mutation records caller, purpose, tenant, object, action, outcome and trace; no secrets or full request body in ordinary logs.

```
POST /v1/prior-authorizations
Idempotency-Key: synthetic-create-001
{
  "patient_id":"pt_syn_1", "coverage_id":"cov_syn_1",
  "order_ref":"ServiceRequest/synthetic-order-1",
  "benefit_type":"medical", "route_id":"route_sandbox_1",
  "urgency":"standard"
}
201: {"id":"pa_syn_1", "state":"draft", "version":1}
```

38. API catalog: connections and clinical records

Recommended contracts | All examples are synthetic and require tenant/purpose checks.

Endpoint	Request -> response / policy and behavior
POST /connections	source_id, organization_id, access_pattern, environment -> connection_id/state. Connection-admin service/staff; idempotent, audit create; unsupported pattern 422. Credentials entered through protected onboarding, not ordinary logs.
GET /connections; GET /connections/{id}	Filters/cursor or ID -> redacted capability/health metadata. Tenant member; safe retry; no tokens/secrets returned; audit read.
POST /connections/{id}/authorize	Allowed redirect + session intent -> authorization URL/session ID. Authorized patient/staff/admin for selected pattern; one-time state and PKCE; audit initiation. Never accept arbitrary return URL.
POST /connections/{id}/refresh	Recommended rename: /sync for record retrieval. Token rotation is internal; /reauthorize starts a new grant when revoked. 202 operation ID; idempotent sync; admin/service entitlement.
GET /patients/{id}	Patient ref -> authorized summary + sources/freshness. Patient-level read policy, paginated linked collections, audit PHI access.
GET /patients/{id}/conditions	Date/source filters -> versioned condition summaries + FHIR refs. Same controls; incomplete-source flags retained.
GET /patients/{id}/medications	Source/type filters -> clearly distinguished orders/statements/dispenses when available; never imply adherence.
GET /patients/{id}/observations	Code-system/code/date filters -> values, units, effective time, status/provenance; invalid filter 422; limited page size.
GET /operations/{id}	Job ID -> state, safe errors, progress/checkpoints. Tenant owner/service; safe retry; avoids synchronous long-pull requests.

Direct /fhir/R4 access is separately scoped and advertised in a CapabilityStatement. A friendly clinical API must preserve FHIR/source references and not silently collapse clinically distinct records into one latest value.

39. API catalog: PA, documents and events

Recommended | Review and submission are separate permissions.

Endpoint	Request -> response / side-effect contract
POST /prior-authorizations	Patient/coverage/order/route -> draft ID/version. Creator scope; idempotent, validate references, audit create.
GET /prior-authorizations/{id}; /status	ID -> timeline/version or last-known transport/review/item decisions with freshness. Reader scope; safe retry, audit. A read need not trigger a payer call.
POST /{id}/review	Expected version + attestation -> immutable reviewed snapshot/hash. Reviewer scope; If-Match; 422 incomplete. Audit reviewer and evidence versions.
POST /{id}/submit	Snapshot/version -> 202 operation ID. Submitter scope; idempotency + If-Match. 409 unreviewed/changed, 422 unsupported route. Audit queue and attempts separately.
POST /{id}/documents	Upload intent/metadata -> short-lived restricted upload; finalize checksum -> scan state. Document scope; size/MIME limits. Document must be clean before submit.
POST /{id}/respond	Information-request ID + reviewed answer/doc refs -> operation/receipt. Reviewer/submitter policy; verify same case; idempotent and audited.
POST /{id}/appeal	Decision/item + grounds + evidence -> draft appeal/task. Authorized staff; no promised automatic payer submission. Idempotent; deadline validated.
POST /webhooks	HTTPS endpoint + event types -> endpoint ID/secret shown once. Tenant admin; endpoint ownership/SSRF checks, signing and rotation.
GET /events; GET /audit-logs	Cursor/time filters -> permitted redacted records. Separate event/auditor roles; bounded export, purpose/tenant checks, audit access to audit data.

All `{id}` shortcuts in this table are beneath `/v1/prior-authorizations`. Add controlled cancel/amend/renew endpoints only when the route contract supports them. Public API responses never expose raw payer credentials or reusable source authorization codes.

40. Connector architecture and onboarding

Recommended | New adapters register capabilities; they do not change the core case model.

```
interface Connector {
  discover(ctx): CapabilityManifest
  authorize(ctx, grantIntent): AuthorizationStart
  readResources(ctx, query, checkpoint): ResourcePage
  fetchDocument(ctx, documentRef): DocumentStream
  requirements(ctx, orderCoverage): RequirementsResult
  submit(ctx, reviewedSnapshot, attemptId): DeliveryResult
  inquire(ctx, externalCaseRef): StatusResult
  attach(ctx, externalCaseRef, evidence): DeliveryResult
  health(ctx): ConnectionHealth
}
// Implement only declared capabilities. Others return
// UNSUPPORTED_CAPABILITY, never synthetic success.
```

Register EpicConnector, OracleHealthConnector, AthenaConnector (product-specific), EClinicalWorksConnector, MEDITECHConnector, HIEConnector, PayerConnector and ClearinghouseConnector through a versioned plugin registry. Each has auth adapter, capability manifest, schema/profile mapping, error mapping and synthetic contract tests. A generic interface does not imply every method is supported.

Manifest fields: protocol/version, resource/search support, writes, attachment limits, notification/inquiry, rate limits, idempotency semantics, auth type, scopes, sandbox/prod endpoints and effective dates. Credentials are resolved via the tenant connection context, never shared global configuration.

Adding a connector

Obtain partner agreement/access -> record capabilities -> implement adapter/mappings -> pass synthetic contract/negative tests -> validate sandbox -> enroll production organization -> canary with approved data -> publish route support. Pin each release and keep rollback compatibility. Pagination, token refresh and retries live in shared libraries only where semantics truly match; preserve native diagnostics safely.

41. FHIR server strategy and decision

Evidence-informed recommendation; no untested performance ranking

Option	Capabilities / operating tradeoff
HAPI FHIR JPA [90] [91]	Open-source Java persistence/server ecosystem; R4 and other version tooling, terminology and partitioning documentation. Extensible interceptors; team owns security configuration, upgrades, database/index tuning and support. Partitioning is not authorization.
LinuxForHealth FHIR [92]	Apache-2.0 open-source R4-oriented server alternative. Evaluate its supported database/runtime, terminology and tenant model against a pinned release. Maintenance cadence and team fit need diligence; no throughput comparison established.
AWS HealthLake [93] [94]	Managed R4 data store with SigV4 or SMART strategy. Reduces server operations; validate required search/operations, quotas, isolation, export and region/pricing. A managed store is not a PAS business engine.
Custom FHIR implementation	Highest control and highest obligation for search, validation, history, references, terminology and compatibility. Avoid implementing the whole standard for MVP. A narrow facade can wrap existing stores but must advertise only supported behavior.

Recommended: start a technical spike with HAPI R4 JPA behind our authorization gateway, using a separate schema/database from business tables. Compare the exact workload to HealthLake before production selection. HAPI's extensibility suits the reference lab; managed infrastructure may win if its contract covers our workload and operations capacity is limited.

Choose based on measured resource/search mix, profile validation, import size, write/read latency, tenant isolation, recovery, licensing/support and 3-year operating cost. Do not benchmark with an empty sandbox and extrapolate to production. Pin released packages/container digests; moving documentation may describe snapshots.

OpenEHR/openFHIR is optional future clinical-modeling infrastructure, not needed merely to emulate the functional connection model. Avoid operating two clinical stores and bidirectional mappings without a concrete business requirement and reconciliation owner. [\[36\]](#)[\[38\]](#)

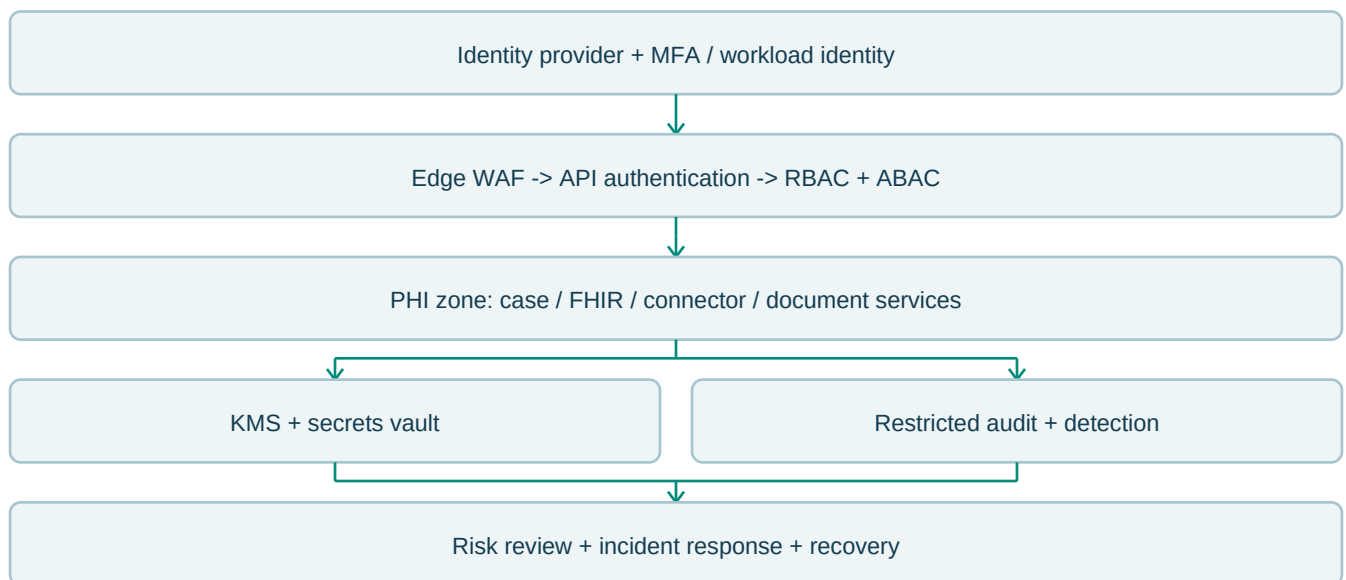
42. Security and compliance architecture

Verified obligations plus recommended controls; architecture alone cannot establish HIPAA compliance.

HHS describes HIPAA administrative, physical and technical safeguards, risk analysis, workforce controls, incident procedures and contingency planning; HITECH extends important obligations to business associates. The current Security Rule and proposed changes are separate. [76][77]

Determine covered-entity/business-associate roles, permitted uses, subcontractors and required BAAs. The Privacy Rule governs use/disclosure and rights; minimum necessary has exceptions, including provider-to-provider treatment disclosures, so legal purpose must be evaluated rather than reduced to a universal checkbox. [78][79][80]

Diagram 11. Security architecture



Recommended. Authorization is rechecked at services/data boundaries; edge authentication alone is insufficient.

Recommended access: staff roles for coordinator, clinician reviewer, admin, support and auditor; ABAC checks tenant, organization, patient/case relationship, purpose, sensitivity and environment. Break-glass access requires justification, time limit and immediate audit review. Support access is just-in-time and case-scoped.

SOC 2 is an assurance report based on defined controls; HITRUST provides a framework and assessment/certification program. Neither substitutes for HIPAA obligations or a project-specific risk assessment. Pursue assurance based on buyer requirements and defined scope; do not label a design certified. [82][83]

43. Security controls and operational duties

Recommended baseline; security begins during discovery, not only in a late roadmap phase.

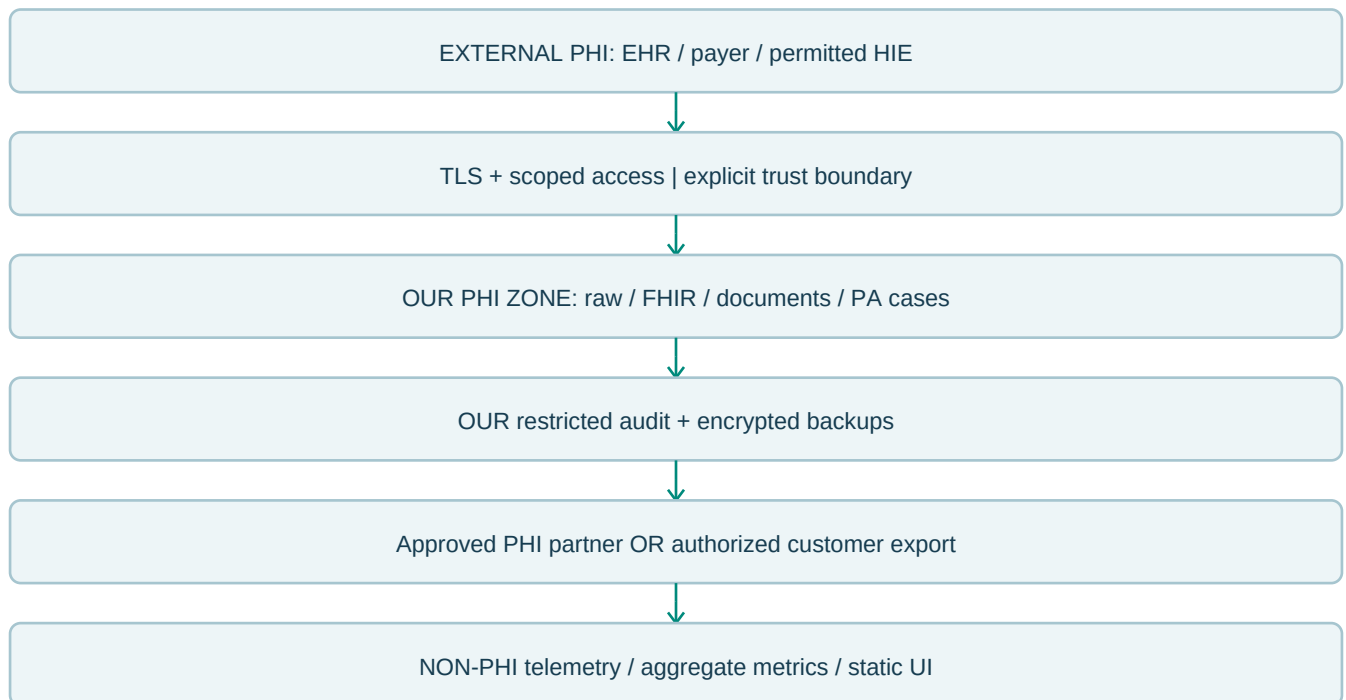
Area	Required implementation evidence
Tokens / keys / secrets	Short-lived scoped tokens, encrypted refresh credentials, private-key/JWK rotation, secret access audit, no shared tenant keys; test revocation and overlap rotation.
Transport / storage	TLS externally and internally where supported; KMS envelope encryption for DB/object/backups; restricted key administration separated from routine operators.
Network	Private services/data stores, least-privilege security groups, controlled egress and VPC endpoints; allowlist partner hosts; no public database.
Documents / code execution	Malware scan and MIME validation; quarantine before use; restricted OCR/rule runtimes; no active document rendering or uncontrolled outbound fetches.
Delivery pipeline	SAST, dependency/license/SBOM, secret and container scanning; signed artifacts; DAST and independent penetration testing before pilot; track remediation.
Consent / PHI handling	Purpose and grant records, revocation propagation, access/export controls, approved subprocessors and minimal external notifications.
Logging	No clinical narrative, tokens, member identifiers or document contents in ordinary telemetry. Restricted audit may contain necessary sensitive references and needs its own access policy.
People / operations	Named privacy/security officials, workforce training, access reviews, vendor assessment, incident exercises and signed runbooks.

Data residency recommendation: select a contracted US region and approved backup region for US PHI unless customer/legal review authorizes otherwise. HIPAA is not a blanket requirement that all data stay in the US. Residency, support access and subprocessors depend on agreements and other applicable law.

44. PHI boundaries, retention and incident response

Recommended data-flow controls; retention is a legal/contractual schedule, not one global number.

Diagram 14. PHI data-flow boundaries



Recommended. Scrub logs and notifications before crossing the non-PHI boundary. Metadata and identifiers can still be sensitive; classify rather than assume anonymous.

Retention classes: configuration lasts through contract/needed evidence; clinical/source data and PA snapshots follow customer/program/legal schedules; policies/mappings retain referenced versions; delivery events have a bounded replay window; credentials are revoked/deleted on termination; audit/security documentation follows applicable requirements. HIPAA documentation retention is not a universal medical-record retention rule. [76][80]

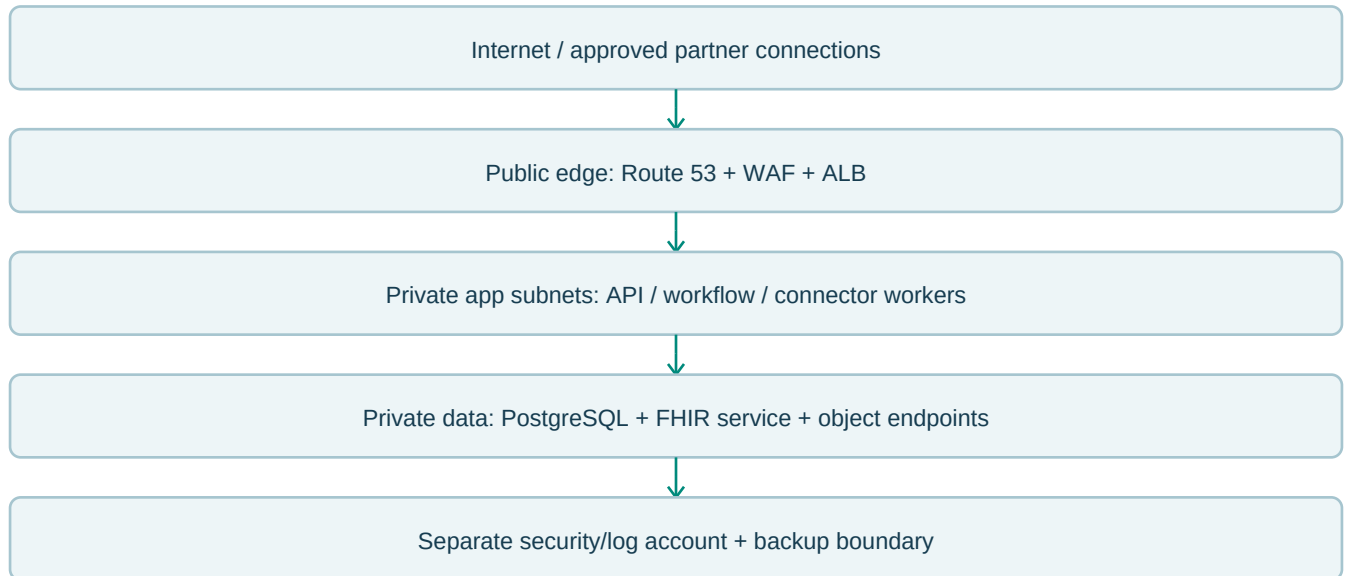
Recommended lifecycle: classify -> assign retention/purpose -> apply legal hold -> restrict access -> expire -> delete active copies and derived indexes -> age out backups under approved schedule -> record deletion evidence. Do not promise immediate removal from immutable backups. Recovered backups must replay deletion/hold decisions before use.

Incident SOP: detect and contain; preserve restricted forensic evidence; revoke affected grants/keys; investigate scope and risk with privacy/legal; notify covered entity and others as applicable; recover, reconcile and remediate. HHS breach guidance includes notification without unreasonable delay and outer limits such as 60 days in applicable cases; contracts can require faster business-associate reporting. Do not treat 60 days as a response target. [81]

45. Cloud deployment and environment separation

Recommended | AWS reference deployment with justified services

Diagram 3. Physical deployment



Recommended. Use at least two availability zones in production. Public ALB terminates ingress; data stores and workers remain private.

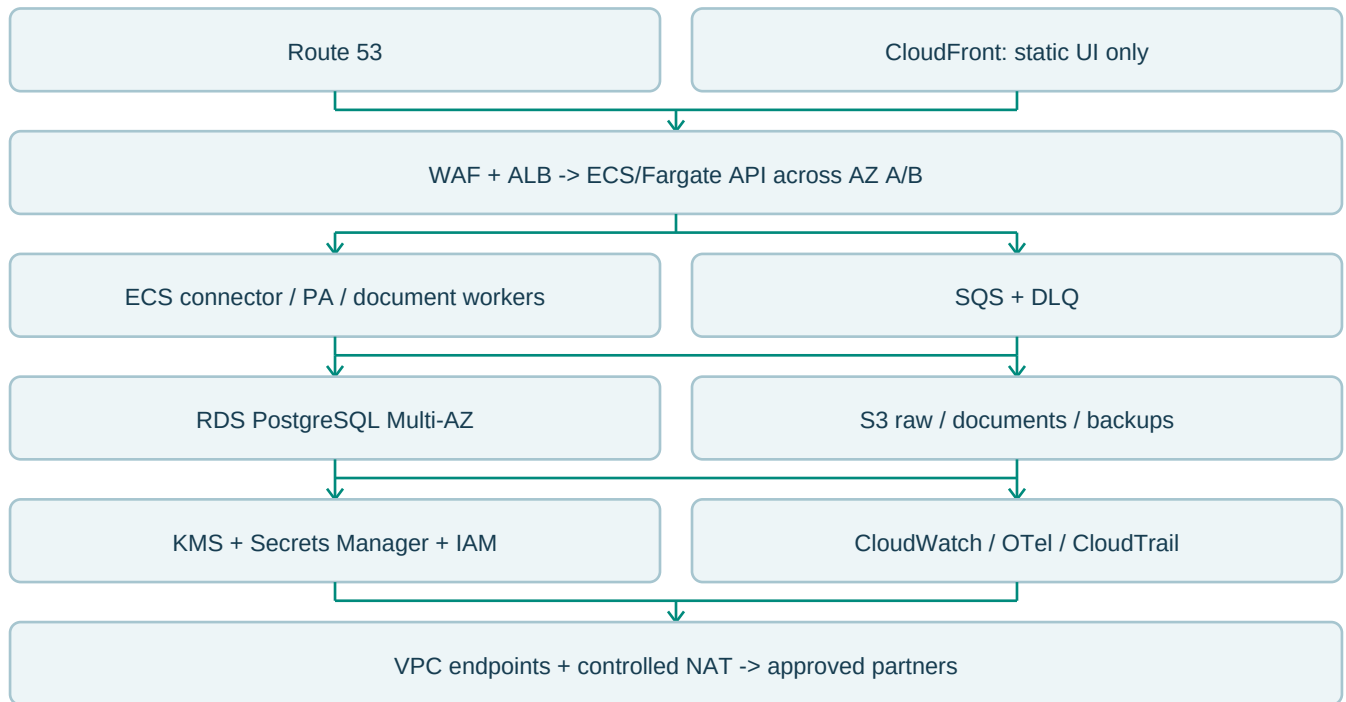
Environment	Isolation and operating policy
Development	Separate account; synthetic data only; local/container FHIR and mock payer; cost limits; no production credentials or copied PHI.
Staging	Separate account; production-like IaC/topology; synthetic fixtures, load/security tests and restore drills; independent OAuth registrations.
Production	Restricted account(s), multi-AZ services, approved PHI flows/BAA's, access reviews, on-call, backups and controlled changes.
Security / audit	Central account with restricted append-only logs, alerting and evidence; administrators cannot casually alter production audit history.

AWS service eligibility and BAA coverage must be checked for each selected PHI-processing service and region/configuration. AWS eligibility does not make our application compliant; customer configuration and organizational controls remain part of shared responsibility. [\[95\]](#)

46. Production AWS reference architecture

Recommended | ECS baseline; EKS only if existing operational capability justifies it.

Diagram 13. Production AWS deployment



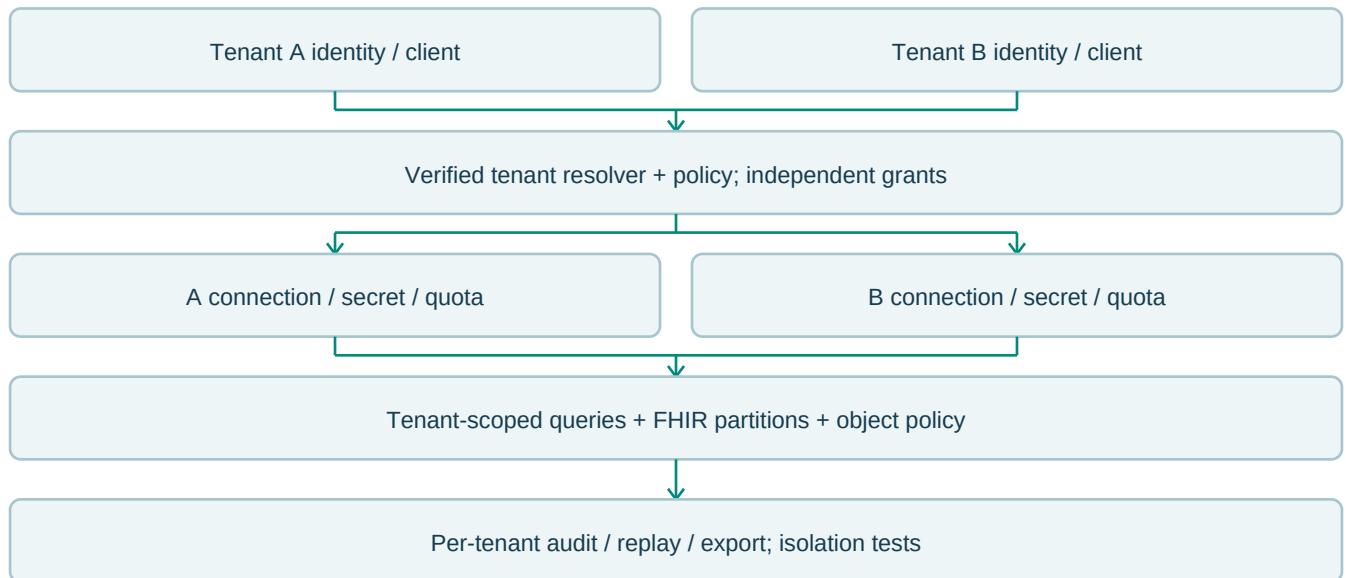
Recommended. CloudFront must not cache PHI responses. RDS business and FHIR schemas/databases remain separate; HealthLake is an alternative to the self-hosted FHIR service.

Service	Reason for inclusion / limits
ALB / API gateway	ALB fits container HTTP ingress; add API Gateway only for a demonstrated API management need, not a duplicate default hop.
ECS / RDS / S3	Managed container operations, relational durable state and encrypted versioned documents. Backups require restore testing.
SQS / DLQ	Decouple slow partner work; durable dispatch and controlled failure handling. Standard queues can redeliver. [96]
ElastiCache (optional)	Rate-limit/token coordination cache only if needed; never the sole case/evidence store.
KMS / Secrets / IAM	Keys, credentials and workload permissions with separate administration.
CloudWatch / OTel / CloudTrail	Metrics, sanitized traces and cloud control-plane audit. CloudTrail does not replace application PHI-access audit.
VPC / endpoints / NAT	Private connectivity to AWS services and controlled external partner egress; monitor cost and destination policy.

47. Multi-tenancy and isolation

Recommended | Start with explicit isolation and a migration path, not a tenant_id convention alone.

Diagram 12. Multi-tenant architecture



Recommended. Arrows represent a common enforcement layer, not permission to mix tenant data. Workers derive tenant from trusted persisted context.

Model	Appropriate use / tradeoff
Shared DB + tenant IDs	Cost-efficient baseline with RLS, composite keys and strict service policy; cross-tenant bug risk demands negative testing.
Separate schema	Some namespace separation; migrations and connection management grow; shared DB administrators still cross boundaries.
Separate database	Stronger backup/restore and access separation; increased fleet operations and cost.
Separate infrastructure/account	Highest practical customer isolation for contractual/regulatory needs; highest cost and rollout burden.

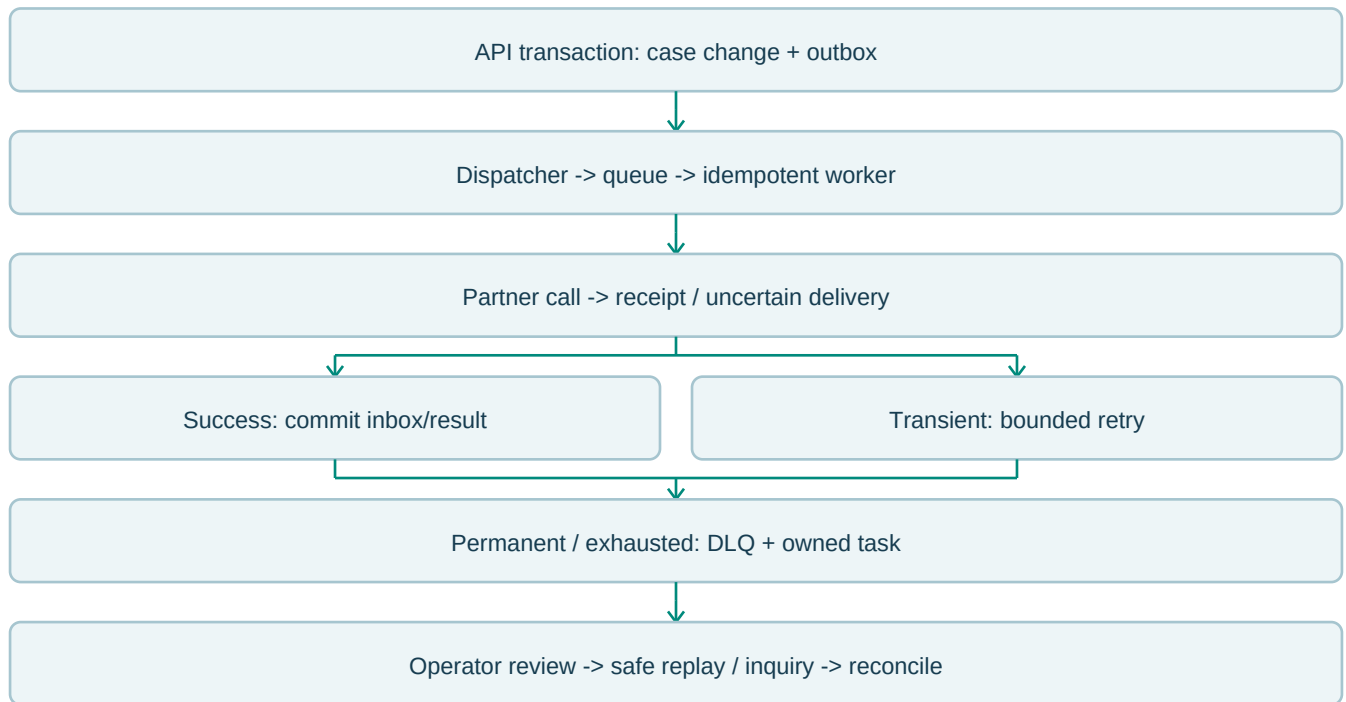
Recommended MVP: one tenant with tenant-aware keys/policy from day one. Pilot multiple tenants only after API, worker, FHIR search/history, export and backup isolation tests. Use dedicated databases/accounts for customers whose contract requires them. HAPI partitioning requires authorization and query checks; it is not by itself a security boundary. [\[91\]](#)

Keep OAuth clients, EHR/payer credentials, webhook secrets, rate limits, feature flags and billing meters tenant-scoped. An admin UI must not allow arbitrary tenant switching. Restrict object prefixes with IAM/service policy, validate signed download context and prevent shared cache keys.

48. Reliability and failure architecture

Recommended | At-least-once work with effectively-once business effects where contracts permit.

Diagram 10. Failure, retry and recovery



Recommended. A timeout after send is uncertain delivery, not proof of failure. Use payer inquiry/correlation before resubmission; do not promise end-to-end exactly-once delivery.

Use exponential backoff with jitter and partner Retry-After; per-tenant and per-route concurrency budgets; circuit breakers; idempotency and payload hash; visibility timeout renewal; durable checkpoints; deduplicated inbox. Persist results before acknowledging queue messages. SQS standard delivery can duplicate messages. [96]

Token expiry: one refresh owner per connection, bounded retry, then reauthorization task. Source outage: retain freshness/partial-data flags. Payer outage: preserve request and deadline, inform staff and activate approved fallback. Invalid profile/identity/permission errors are not retryable without correction. DLQ replay needs authorization and recorded rationale.

Webhook contract: signed raw body plus timestamp/replay tolerance, unique event ID and schema version. Receiver durably records then acknowledges quickly; business work runs asynchronously. Retry with capped backoff; disable unhealthy endpoints after policy threshold and notify admin. GET /events supplies authorized replay; deliveries never expose credentials.

49. Observability, SLOs and disaster recovery

Recommended targets for planning; validate with stakeholders and measured workload.

Measure / example target	Alert / action
API availability 99.9% monthly	Budget about 43 minutes/month for a 30-day month. Measure our API separately from payer decision time.
Interactive API p95 < 1 second	Exclude async partner work; alert sustained >2 seconds for 10 minutes with minimum traffic.
Queue oldest-job age	Alert >5 minutes for routine ingestion or >1 minute for urgent dispatch; adapt to agreed clinical workflow.
Connector/token failure	Alert sustained >5% technical failures over 15 minutes or repeated refresh failures; suppress low-volume noise with absolute counts.
Payer response / case SLA	Detect stalled receipts and approaching configurable deadlines; operators own escalation.
Validation / security	Any wrong-tenant/patient access = incident; increases in FHIR rejection or unmapped critical codes trigger release/route review.
Webhook / jobs	Monitor retry exhaustion, DLQ >0, duplicate suppression, replay and scheduler heartbeat.
Data integrity	Reconcile snapshot hashes, counts, decision linkage and EHR writeback backlog daily or more often for urgent routes.

Proposed recovery targets: production case database RPO <=15 minutes and RTO <=4 hours; stricter targets require investment and partner review. Multi-AZ supports local resilience, not region-wide disaster recovery. Maintain encrypted point-in-time backups and an approved secondary-region recovery plan; restore keys, secrets/configuration and applications as well as data.

Run restore and reconciliation drills before pilot and periodically thereafter. Rebuild queues from durable jobs/outbox after recovery; identify requests whose send/receipt state is uncertain. Stop submissions until identity, policy and active-route configuration are verified. Instrument traces with opaque references; detailed PHI debugging belongs in a separately authorized workflow.

50. Admin, developer and operating experience

Recommended | Make health, evidence and ownership visible.

Surface	Essential behavior
Staff workbench	Case list, age/deadline, source completeness, evidence viewer, missing-data tasks, review/attestation, submission receipt and item-level decisions.
Admin console	Organizations/roles, approved endpoints, connection/grant status, route capability, credential rotation, quotas, export/retention configuration and audit access.
Developer portal	OpenAPI/FHIR CapabilityStatement, SMART registration instructions, SDKs, synthetic sandbox, event schemas, sample errors and migration policy.
Operations console	Job/route health, safe retry/replay, DLQ ownership, change history, incident links and dependency status.
SDKs	TypeScript first, generated typed clients where useful, pagination/retry helpers, signature verifier; no silent auto-retry of uncertain PA submissions.
Analytics	Touch time, queue age, receipt/decision latency, information requests, fallback and technical failure rates stratified by route.

Recommended product copy: show access granted separately from records ready; submitted separately from acknowledged; pending separately from denied. Display last-reconciled time during partner outages. Explain what staff must do next using ordinary language, not FHIR resource names.

Operational SOP: before a release verify profile/package changes and synthetic route tests; during rollout canary one approved route; monitor errors/queue age; roll back adapter changes without deleting case history. For support, capture sanitized trace IDs and scoped evidence access instead of emailing patient documents.

51. Testing and acceptance strategy

Recommended tests, not claimed results; synthetic data until approvals and agreements.

Test layer	Evidence and example failure
Unit / policy	State transitions, deadline configuration, idempotency, mapping and tenant/purpose decisions; stale attestation rejected.
FHIR / terminology	Pinned validator/packages; invalid references/codes/units; DocumentReference/Binary access; missing data remains unknown.
Connector contracts	Recorded synthetic requests/responses for pagination, scope denial, rate limits, refresh, source version differences and unsupported capability.
Sandbox / E2E	One continuous patient/order/coverage through CRD/DTR/PAS, pending/information loop and item-level decision; trace IDs and snapshots.
Partner acceptance	Exact EHR/payer/plan route in approved sandbox; evidence of enrollment and production contract differences.
Security / privacy	Cross-tenant access, SSRF, webhook forgery/replay, secret exposure, role escalation, document malware and unauthorized export.
Performance / reliability	Realistic resource/document volumes, rate-limit constraints, worker crash, duplicate events, timeout-after-send and restore.
Audit / data integrity	Every protected read/mutation traceable; source-to-answer-to-request chain preserved; exports and deletion/hold behavior verified.

Use HL7 paired br-provider/br-payer RIs for protocol learning and synthetic harnesses; use actor-specific Inferno suites for their covered requirements. Neither RI demo success nor an Inferno pass proves all partner workflows or production security. Pin builds and retain test reports. [97][98][99]

Exit criteria

All critical scenarios pass; no unresolved patient/tenant isolation defects; required profile/partner checks pass; review and decision semantics verified; restore/export/replay demonstrated; privacy/security and operational owners sign off. Keep expected/actual messages, artifact versions, dates, operators and limitations with each result.

52. Build, buy, open source and partner decisions

Recommended classifications; validate license and operating fit before adoption.

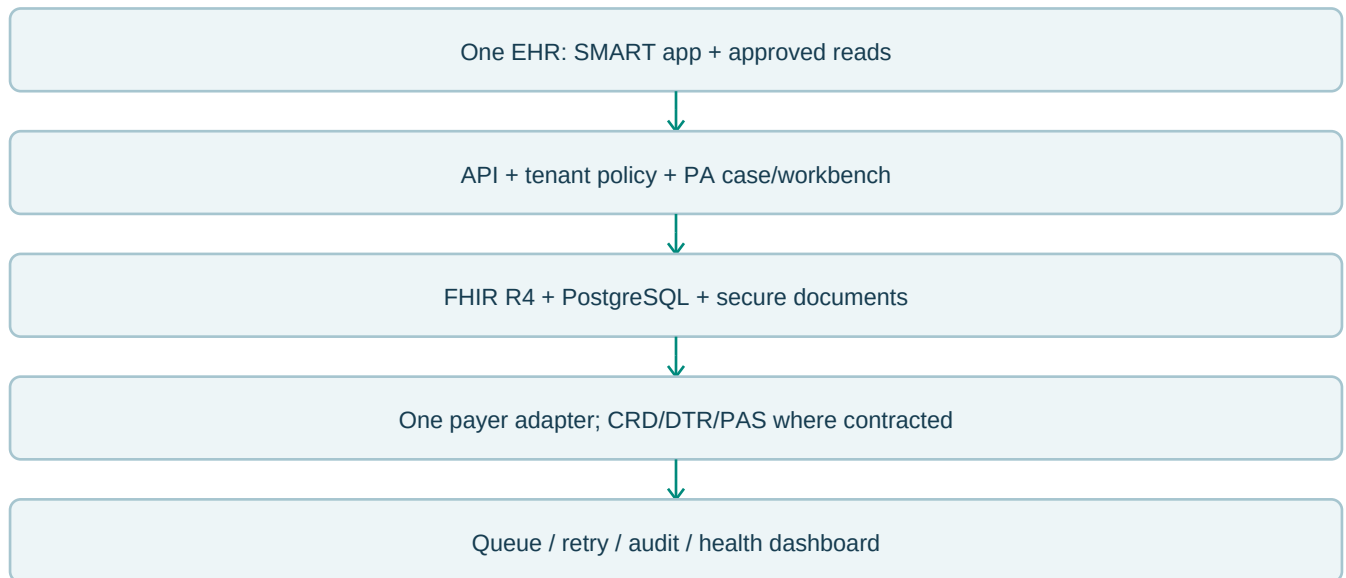
Subsystem	Choice	Reason / retained responsibility
FHIR server	OPEN SOURCE / HYBRID	HAPI spike; compare managed HealthLake. We retain profiles, authorization and operations decisions.
Terminology	HYBRID	Reuse server operations; obtain licensed content and govern mappings/releases internally.
Identity / OAuth / SMART	BUY / OPEN SOURCE	Use maintained identity and SMART libraries; build policy integration, not cryptography.
API gateway / queue	BUY	Managed infrastructure reduces commodity operations; we own quotas, idempotency and event meaning.
Observability	HYBRID	Managed metrics + OpenTelemetry; we own PHI scrubbing, SLOs and incident response.
Documents / OCR	HYBRID	Buy/reuse scanning/OCR where approved; own provenance and human review; OCR optional for structured MVP.
Payer / clearinghouse	PARTNER / HYBRID	Purchase proven reach where useful; own route ledger, case state and reconciliation.
HIE connectivity	PARTNER	Agreements/trust/onboarding matter as much as API code; defer until need is established.
PA rules / criteria	BUILD + PARTNER	Build routing/state/review; consume licensed payer criteria and supported questionnaires.
PA workspace / case APIs	BUILD	Differentiating operations, UX and evidence trail.
Clinical modeling / openFHIR	LATER / OPTIONAL	Reuse only if openEHR mapping is justified; current repository warnings require review. [38]

For every purchased component require data export, environment support, termination assistance, security terms, incident reporting, service scope and unit pricing. For every open-source component require a pinned release, SBOM, license review, patch owner and recovery plan. Open source removes some license fees, not implementation or clinical risk.

53. MVP scope and architecture

Recommended | One specialty, one provider organization, one EHR and one real partner route.

Diagram 15. MVP architecture



Recommended. Where a partner lacks a standard interaction, use a clearly labeled staff-assisted route; do not call it a standards-conformant automated flow.

Priority	Scope
MUST HAVE	Identity/tenant policy; scoped connection; patient/coverage/order/evidence; provenance; staff review; one submit/status/information loop; documents; receipts; audit; safe retries; export; security agreements and operations.
SHOULD HAVE	SMART embedded launch; supported CRD/DTR/PAS contract; signed webhooks; minimal admin portal; coding validation; controlled EHR writeback; workflow metrics.
LATER	Second EHR, more payer plans, national HIE, pharmacy network, advanced OCR/AI, autonomous criteria suggestions, warehouse, enterprise isolation tiers and cross-region active-active.

Choose a medically coherent specialty and representative cases with the pilot partner; this proposal does not invent a partner commitment. If no payer API is available, a staff-assisted MVP can still test evidence preparation and case tracking, but must be marketed and measured accordingly. Do not count a public sandbox as a production connection.

54. Implementation roadmap: phases 0-3

Recommended sequence; some work overlaps, but access and security gates remain explicit.

Phase / objective	Technical + business deliverables; dependencies, risk and exit
0 Discovery	Confirm actor, specialty, benefit, partner and route; baseline workflow and economics; source/assumption/requirements register. Dependency: kickoff and sponsor. Risk: wrong buyer or inaccessible route. Exit: scoped use case, partner owner and synthetic scenarios.
1 Architecture	Threat model, data model, version manifest, connector/API contracts, ADRs, cloud/IAM design and retention decisions. Business: responsibilities, criteria/IP and procurement plan. Dependency: phase 0. Risk: designing around unproven APIs. Exit: reviewed blueprint and route feasibility.
2 FHIR foundation	Deploy pinned isolated FHIR stack, validation, terminology subset, source/provenance model and synthetic fixtures. Business: terminology/license review. Dependency: phase 1. Risk: unsuitable search/tenant model. Exit: representative import/query/profile and isolation tests.
3 Identity/authentication	Staff federation, tenant membership, SMART launch/backend registration, key/secret lifecycle and audit. Business: organization approvals/BAA's. Dependency: threat model and source access. Risk: unsupported grant/scope. Exit: valid grant, revoke/expiry and cross-tenant negative tests.

Security controls start in phase 0 and are implemented throughout. Phase 8 is a formal hardening/readiness gate, not the first point at which security work begins. Track external access dependencies separately from developer work so schedule estimates do not conceal waiting time.

55. Implementation roadmap: phases 4-7

Recommended | Prove one continuous case before expanding routes.

Phase / objective	Technical + business deliverables; dependencies, risk and exit
4 EHR connectivity	Implement one adapter, metadata/scopes, pagination, notes/documents and rate control. Business: sponsor activation and support agreement. Dependency: phase 3 and sandbox. Risk: production/sandbox gap. Exit: agreed patient/coverage/order/evidence read set and permissions proven.
5 Normalization	Mapping/provenance, identity crosswalks, code/unit validation, document scan and completeness flags. Business: SME mapping sign-off. Dependency: phase 4 sample shapes. Risk: clinically wrong equivalence. Exit: curated synthetic mappings and ambiguity handling pass.
6 Payer connectivity	Enroll route, configure auth, capabilities, receipt/status and attachments; native payload archive. Business: contract, delegated authority and SLA. Dependency: partner access and case model. Risk: API unavailable or insufficient. Exit: witnessed synthetic submit/receipt/inquiry/attachment route.
7 Prior Authorization	Workbench, requirements, DTR/evidence, review, immutable submission, pending/RFI, decision, EHR update and appeal task. Business: operations SOP and training. Dependency: 4-6. Risk: workflow stalls outside happy path. Exit: end-to-end and negative scenarios with measurable residual effort.

Use a route-ready definition: named plan/benefit/service, authorized provider identity, supported operations, environment/version, credentials, attachments, failure behavior and partner acceptance evidence. A product announcement, network logo or endpoint URL does not satisfy the gate.

56. Implementation roadmap: phases 8-10

Recommended | Bounded production scope, measured expansion

Phase / objective	Technical + business deliverables; dependencies, risk and exit
8 Hardening	Pen test, dependency patching, load/restore/replay, audit completeness, alert/runbook rehearsal and data disposition controls. Business: risk assessment, workforce/vendor evidence and incident agreements. Dependency: integrated flow. Risk: late control gaps. Exit: critical findings closed and accountable approvals.
9 Production pilot	Approved small cohort/route, canary deployment, staffed reconciliation, daily case review and baseline comparison. Business: user training, support, safety and contract sign-off. Dependency: 8 + production onboarding. Risk: unseen real-world variation. Exit: agreed safety/reliability/economic targets and complete exception ownership.
10 Scale	Additional adapters/tenants, dedicated isolation where needed, capacity optimization, disaster recovery maturity and optional pharmacy/HIE. Business: repeatable onboarding, commercial packaging and assurance program. Dependency: successful pilot. Risk: connection maintenance outgrows team. Exit: repeatable deployment and route onboarding with sustainable TCO.

Suggested timing assumptions

For a capable 6-8 FTE-equivalent team with timely access, allow roughly 4-6 months to an integrated synthetic MVP, then 2-3 additional months for a bounded production pilot. Broader production maturity may require another 3-6 months; enterprise breadth is ongoing. These are estimates, not commitments. Contracting, credentials and clinical-content rights can move every date.

Release evidence

Keep architecture revision, package manifests, route contracts, test results, security approvals, operational runbooks and known limitations together. Rollout by tenant and route with feature flags; rollback the adapter while preserving case and evidence history. Do not approve national expansion from one successful pilot.

57. Team structure and governance

Recommended roles; individuals may cover several roles, but responsibilities cannot disappear.

Role	MVP responsibility / enterprise expansion
Product manager + healthcare BA	Buyer/workflow discovery, scope and acceptance; later segment and portfolio ownership.
Interoperability architect / FHIR engineer	Profiles, data contracts, standards and design decisions; later connector/standards governance.
Backend / integration engineers	Case engine, APIs, adapters and reconciliation; later dedicated route teams.
Frontend / UX engineer	SMART app/workbench and safe review experience; later admin/developer surfaces.
QA automation engineer	Synthetic fixtures, protocol/E2E/negative tests and regression evidence; later performance/partner certification specialization.
Security / privacy / compliance	Risk assessment, agreements, threat/control review and incident obligations; retained fractional expertise in MVP, dedicated enterprise owners.
DevOps / SRE	IaC, CI/CD, observability, recovery and on-call; enterprise 24/7 coverage and capacity.
Clinical / PA SME	Evidence correctness, workflow and attestation/appeal handling; later specialty governance and policy change review.
Partner operations / customer success	EHR/payer onboarding, credentials, training, support and SLA ownership; expand with live route count.

Illustrative MVP staffing: 1 product/BA, 1 architect/FHIR lead, 2 backend/integration engineers, 1 frontend, 1 QA, 0.5-1 SRE/security capacity plus fractional PA SME and privacy/legal. This is about 6-8 delivery FTE equivalents, not a claim that one person can independently perform every assurance function.

Governance: product owns value/scope; clinical owner owns attestation and evidence rules; architecture owns contracts; security/privacy own risk acceptance; operations owns pending cases; executive sponsor owns funding and external commitments. Require separation of development, production approval and privileged access wherever practical.

58. Risk register: integrations and data

Recommended project assessments, not scores of vendors or regulatory actors. H/M/L are qualitative.

Risk / probability / impact	Mitigation / owner
EHR differences H/H	Per-product capability manifest, fixture suite and explicit supported version; integration lead.
Payer/plan/delegate differences H/H	Route ledger, enrollment proof and scoped contract tests; partner operations.
API unavailable / roadmap only H/H	Validate before commitment; supported fallback and phased scope; product/architect.
Sandbox differs from production H/H	Production checklist and approved canary; integration/QA.
Credentials/onboarding delays H/H	Start commercial/security engagement early; track external lead time; partner manager.
Data incomplete / poor quality H/H	Completeness/freshness flags, missing-data queue and provenance; data/clinical lead.
Terminology mismatch H/H	Versioned licensed mappings, validation and human review; terminology SME.
Patient identity mismatch M/Critical	Namespaced IDs, verified crosswalks, no unreviewed fuzzy merge; security/data lead.
Consent/purpose mismatch M/H	Policy evaluation, grant records and access review; privacy owner.
Token expiry/revocation H/M	Single-flight refresh, reconnect task and bounded retries; integration lead.
Rate limits/outage H/H	Budgets, jitter, circuit breakers, checkpoints and reconciliation; SRE.

Qualitative likelihood reflects project complexity under the stated scope, not actuarial probabilities. Reassess with the actual partners and observed incidents. Treat critical identity and unauthorized disclosure risks as launch gates even when likelihood is estimated medium.

59. Risk register: governance and operations

Recommended | Unknowns must have an owner and a resolution gate.

Risk / probability / impact	Mitigation / owner
Regulatory change M/H	Applicability register and official-source review before release; compliance.
PHI exposure M/Critical	Threat modeling, least privilege, logging controls, independent testing and IR; security.
Retention/deletion mismatch M/H	Class-specific schedule, legal holds and backup policy; privacy/legal.
Vendor lock-in M/H	Portable case/evidence export, adapter boundary and exit terms; architect/procurement.
Unexpected protocol semantics H/H	Preserve raw response, test negative paths and pin versions; integration/QA.
Duplicate submission M/H	Idempotency, uncertain-delivery state and inquiry before resend; backend lead.
AI/OCR fabricates evidence M/H	Candidate facts with source citation, review and explicit unknowns; clinical lead.
Policy/IP rights missing M/H	License criteria/code sets and maintain effective versions; legal/SME.
Missed information request M/H	Owned task, deadline alert, reconciliation and daily queue review; PA operations.
Unsustainable manual residual H/H	Track vendor and internal labor, adjust price/scope; product/finance.
Recovery restores stale rights M/H	Reapply deletion/revocation, reconcile uncertain sends before restart; SRE/security.

Major unresolved decisions

Which specialty and exact payer plan? Which EHR/product/version and sponsor? Are CRD/DTR/PAS endpoints available in a partner sandbox and production? What content may be licensed/redistributed? Which staff can attest? What region/retention/isolation is contracted? What volume, urgency and support hours are required? Resolve these in phase 0-1; the report does not fabricate answers.

60. Cost and effort model

Recommended planning estimates; no cloud/vendor quote or guaranteed delivery date

Stage	Incremental effort / elapsed allowance	Assumptions and main cost drivers
Synthetic MVP	24-48 person-months; 4-6 months	6-8 FTE equivalents; one EHR/payer route; reuse FHIR/identity; limited specialty and human review.
Production pilot	12-24 additional person-months; 2-3 months	Hardening, onboarding, training, observation and remediation; partner access available.
Broader production	24-60 additional person-months; 3-6 months	More routes/tenants, recovery, support and customer controls; no nationwide coverage claim.
Enterprise expansion	60-144+ additional person-months; 6-12+ months	10-12 FTE equivalents illustrative; number of routes/specialties and isolation tiers dominate.

Effort covers the delivery team, including engineering/QA/platform/product contributions; specialized legal, audit, licensed criteria and external vendor fees are additional. Stages are incremental, not overlapping totals. At an illustrative loaded cost of \$15,000-\$25,000 per person-month, MVP labor is \$360,000-\$1.2 million. Replace this assumption with actual hiring/contracting rates; it is not a market salary survey.

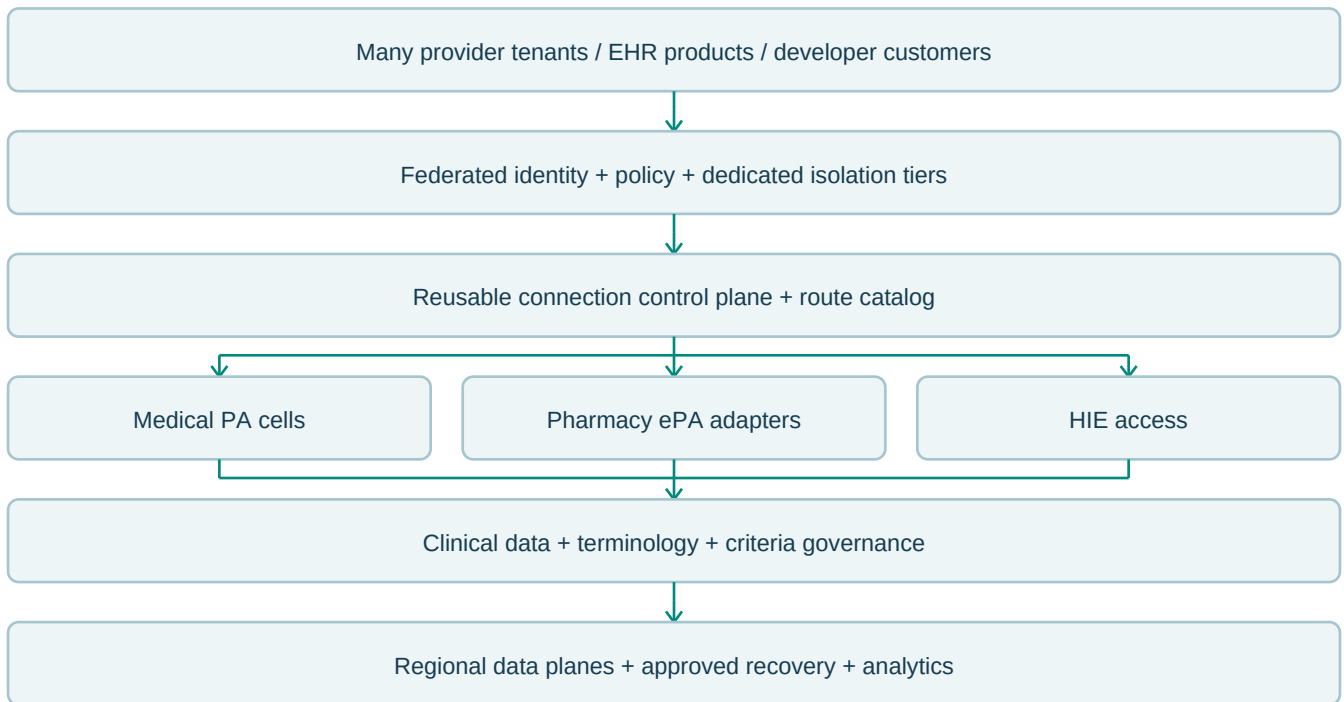
Cost category	Estimate method / key sensitivity
Infrastructure	Compute task-hours + DB/storage/IO + S3/requests + queue + logging + network/backup. Model dev/staging/prod separately; no invented AWS SKU price.
Compliance/security	Risk review, legal/BAA's, penetration testing, training, assurance and remediation; obtain scoped quotes.
Integration onboarding	Per partner: application/contracting, adapter work, certification, deployment and support; elapsed waiting can exceed coding.
Ongoing maintenance	Plan 2-4 FTE equivalents for a narrow live product across integration/support/SRE/QA, plus SME/security access; scale with routes and service hours.

Use low/base/high volume and automation scenarios. Do not count staff capacity as cash savings without a staffing/throughput change. Re-estimate after the first connector and payer acceptance test; those results are more informative than a detailed but unvalidated national rollout estimate.

61. Future-state enterprise architecture

Recommended | Add breadth only after the core case and evidence chain is reliable.

Diagram 16. Future enterprise architecture



Recommended. A cell is a bounded group of tenants/workers/data resources to limit fault impact. Medical and pharmacy exchange remain separate adapters.

Future features: contract-tested connector SDK, self-service synthetic onboarding, approved tenant provisioning, specialty policy libraries, reusable DTR capability, customer-managed keys where justified, mature operational analytics and supported higher-availability tiers. Introduce separate workflow infrastructure or regional cells only when workload and failure isolation justify complexity.

Enterprise operating requirements include change notification, API deprecation policy, audit evidence collection, 24/7 response as contracted, dependency lifecycle, partner certification cadence, clinical content governance and customer exit support. A broader API catalog is insufficient without a repeatable enrollment/support process.

Do not build payer-side autonomous clinical adjudication by quietly extending the provider-side workflow. That changes accountability, policy validation and governance. Revisit business architecture, permissions and clinical oversight as a separate product decision.

62. Consolidated target architecture

Recommended final design | One continuous clinical-to-payer evidence chain

Consolidated architecture: target system



Open-source component candidate: HAPI FHIR. Third parties are optional per route. Payer exchange can bypass intermediaries. All PHI stores/workers are within the approved boundary; external disclosure requires the correct authority.

The differentiating asset is a dependable case and evidence chain: who requested care, which source facts supported which reviewed answers, what exact request was sent, what receipt arrived, who must act next, and what the payer decided. Preserve that chain across every connector, retry, tenant and product evolution.

63. Decision records and immediate execution plan

Recommended approval package; no procurement or deployment has been authorized by this report.

ADR	Proposed decision / revisit trigger
ADR-01 Scope	Medical-service provider MVP with one route. Revisit if medication or payer buyer dominates discovery.
ADR-02 Data	R4 exchange + source provenance + business case DB + document store. Revisit openEHR only for demonstrated modeling need.
ADR-03 Workflow	Durable case state/outbox and human attestation; independent transport attempts. Revisit orchestration engine when complexity justifies it.
ADR-04 Connectivity	Hybrid: own case/control, buy/partner for proven reach. Revisit with measured route coverage/TCO.
ADR-05 Security/tenancy	Explicit tenant/purpose policy, server-side credentials and separate environments; dedicated tiers when contracted.
ADR-06 Cloud/FHIR	AWS ECS/RDS/S3/SQS baseline; HAPI spike versus HealthLake workload proof before production choice.

First ten working days, subject to partner availability

Days 1-2: product/SME select specialty, plan and EHR sponsor; map current workflow. Days 3-4: integration lead obtains capability and onboarding evidence; security begins threat/data review. Days 5-6: engineering creates synthetic patient/order/coverage fixtures and version manifest. Days 7-8: spike SMART read + evidence trace and payer request/receipt with approved sandbox. Days 9-10: review failures, compare build/buy route evidence and approve a bounded backlog/ADR revision.

Completion evidence and conclusion

This blueprint links public research, architecture decisions, implementation contracts, an evaluation SOP and a proposed validation plan. It is sufficient to begin scoped design and partner diligence. It does not establish live connectivity, vendor selection, HIPAA compliance or conformance. The next meaningful milestone is one witnessed synthetic continuous case on the intended EHR/payer route.

64. Glossary: healthcare and interoperability

Plain-language terms for executive and engineering readers

Term	Meaning
EHR / EMR	Electronic health/medical record system; EHR commonly emphasizes broader longitudinal/exchange workflows.
FHIR / FHIR resource	HL7 exchange framework / a typed unit such as Patient or Observation.
FHIR server	System implementing declared FHIR storage/query/exchange operations; not automatically an EHR or PA engine.
SMART	OAuth-based healthcare app launch/access patterns with clinical context.
USCDI / US Core	US data classes/elements / FHIR profiles and interactions supporting US exchange.
HIE / TEFCA	Health information exchange / national trust framework for exchange; neither guarantees all records or PA routing.
CRD / DTR / PAS	Coverage Requirements Discovery / Documentation Templates and Rules / Prior Authorization Support.
X12 278	Administrative health-care services review transaction used in authorization/referral workflows.
PA	Payer review required before some care; a coverage determination is distinct from app data-access permission.
Provider / payer	Care-delivery person/organization / organization administering coverage.
PBM	Pharmacy benefit manager; medication-benefit workflows differ from medical-service PA.
Clearinghouse	Intermediary that transforms/routes administrative transactions under appropriate agreements.

65. Glossary: security, terminology and software

Terms used in the implementation contracts

Term	Meaning
PHI / HIPAA / BAA	Protected health information / US health-information rules / business associate agreement.
SNOMED CT / LOINC	Clinical terminology / identifiers for observations and related clinical content.
RxNorm / NDC	Normalized drug concepts / drug product-package identifiers; different purposes.
ICD-10-CM / CPT / HCPCS	US diagnosis classification / physician procedure terminology / health-care service/supply codes, including CPT Level I and Level II.
OAuth / OIDC	Delegated API authorization / identity layer on OAuth; access tokens and ID tokens have different uses.
Webhook	Push event delivery to an HTTPS receiver; authenticate, deduplicate and handle retries.
Idempotency	Repeating the same logical operation does not create an additional business effect under its defined contract.
RBAC / ABAC	Role-based / attribute-based access policy.
CQL / ELM	Clinical Quality Language / its executable expression representation in supported clinical-rule workflows.
RPO / RTO / SLO	Maximum planned recoverable data-loss window / recovery time objective / measured service-level target.
DLQ / outbox / inbox	Failed-work queue / durable transaction-linked events / deduplicated received-event ledger.
Provenance / attestation	Origin/transformation history / accountable human confirmation of submitted evidence.

66. Appendix: Matrix A: provider automation and connectivity

Publicly described capabilities; no row represents an independently verified deployment.

Vendor / buyer	Channels and workflow	Pricing signal / evidence
Waystar Provider RCM and patient-access teams	EHR/HIS/PM-connected authorization modules: requirement verification, initiation, submission, attachments and status. Medical-service orientation. Exact payer transport and writeback scope require confirmation.	No numeric price in reviewed product page; customized plan / tour. [04]
Infinx Provider enterprises and outpatient groups	EHR integration and web portal; electronic initiation, follow-up and approval updates. Automation plus specialist handling when electronic processing is unavailable.	No numeric price in reviewed page; sales-led software/services scope. Separate human-work fees in RFP. [05][06]
Humata Health Providers; separate payer offering	Medical-service and drug products; policy matching, clinical bundling, submission support, automated statusing and post-auth monitoring. Public overview does not define every transport.	No numeric price in reviewed overview; obtain scoped quote. [07]
Availity Providers, payers, technology partners	Essentials web authorization workflow and API Marketplace. APIs list create, status, attachments, CRD and PAS. Payer/plan enrollment and route capability must be checked.	API pricing not numerically disclosed in reviewed marketplace. Portal and API entitlements are separate. [09][10][11]

What the matrix does not establish

Marketing references to automation, real-time results or end-to-end coverage do not establish zero staff work, universal payer coverage, a clinical approval guarantee or appeal automation. Ask each vendor to show the same synthetic case through both a routine path and an exception path. Record which tasks are automated, vendor-staffed or left to your team.

67. Appendix: Matrix B: payer UM and pharmacy ePA

The purchaser, participating provider and decision-maker may be different organizations.

Vendor / buyer	Channels and workflow	Pricing signal / evidence
Cohere Health Health plans / UM leadership	In-house and delegated UM; provider participation; Connect claims CRD/DTR/PAS support. Clinical review and wider appeals offerings are marketed. Validate modules and delegated scope.	Customized health-plan offering; no numeric rate in reviewed sources. [12] [13]
EviCore by Evernorth Health plans / delegated UM; providers are submitters	Health-plan/solution-specific provider portals; case creation, added clinical information and consultation resources. Program routing drives access.	No numeric enterprise price in reviewed provider resources. Provider portal access is not an enterprise UM quote. [14] [15] [16]
CoverMyMeds Prescribers/staff; EHR and pharmacy integration partners	Medication PA portal and EHR workflows. Provider ePA API and pharmacy NCPDP Telecom interface. Completion, tracking, determinations and renewals described.	Provider/staff ePA stated no cost; API access requested separately, no public API rate in reviewed page. [17] [18]
Surescripts Prescribers/staff; EHR vendors and PBM/payer partners	Medication ePA through integrated systems and web portal. NCPDP SCRIPT companion documentation and message-flow guidance.	Free provider portal explicitly stated. Integration/network commercial terms not priced in reviewed sources. [19] [20] [21] [22]

Implication for the shortlist

A provider team may need to interact with a payer-selected UM vendor regardless of the provider automation product it buys. Conversely, a payer selecting a UM platform needs clinical governance and delegation controls that are outside the scope of an ordinary provider submission tool. Medication-network functionality must be tested against the actual benefit and PBM route.

68. Appendix: Matrix C: integration components and substitutes

Buy a component for a defined responsibility; retain explicit ownership of everything else.

Option / buyer	Documented role and limits	Pricing signal / evidence
Redox Health-technology integration teams	FHIR API PA submission and attachments on supported digital connections; sync/async behavior varies by connection. Manual-only portal/fax connections are explicitly excluded for this action.	No numeric PA price in reviewed technical page; contact sales/TAM. [23]
Medblocks Health-app developers	SMART App Launch and CDS Hooks EHR context. Organizational relationship required; clinician-workflow docs are WIP. PA submission not established.	Free \$0 / 1,000 active patients; Enterprise \$60,000/year, uncapped, with Backend Services and Clinical Workflows. Platform list prices only. [24][25]
Existing EHR + payer portals Your organization	Baseline substitute, not an additional named vendor assessment. Inventory licensed native features and payer-required portals before adding another application.	Measure current license entitlements, staff time and integration charges; no assumed zero total cost.
Internal build + standards Your engineering team	Maximum control over orchestration, but code does not create payer connectivity, business agreements or clinical policy rights.	Budget engineering, onboarding, content maintenance, support and ongoing conformance. No vendor price applies.

Redox and Medblocks are not equivalent PA products

Redox documents Claim/\$submit-preauthorization and attachment behavior. That vendor operation name alone does not prove conformance to the complete Da Vinci PAS lifecycle. Medblocks documents upstream app launch/context, not an equivalent submission operation. Evaluate the two against different component contracts. [23][24]

Substitute analysis

Existing EHR functionality may be the lowest-friction starting point if licensed and supported for the needed routes. Staffed portal workflows may remain necessary for exceptions. Neither should be dismissed without measuring current touch time, rework, missed deadlines and ability to retain audit evidence.

69. Appendix: Workflow coverage crosswalk

P = public product description; T = technical documentation; ? = not established in reviewed sources.

These marks measure available evidence, not feature quality. They are constrained by the route and benefit described in the vendor matrices. A question mark does not mean the vendor cannot support the capability. No cell is an executed test result.

Vendor	Need check	Prepare evidence	Submit	Track / decision	Appeal handling
Waystar [04]	P	P	P	P	?
Infinx [05]	P	P	P	P	?
Humata [07]	P	P	P*	P	?
Availity [09][10]	P	P*	P	P	?
Cohere [12][13]	P*	P	P*	P	P*
EviCore [14][15]	?	P*	P	P	?
CoverMyMeds [17][18]	?	P	P/T	P/T	?
Surescripts [19][21][22]	?	P/T	P/T	P/T	?
Redox [23]	?	T*	T	T*	?
Medblocks [24]	?	P*	?	?	?

* Narrow scope: Humata says submission support; establish fully automated versus assisted. Availity/EviCore document supporting-clinical upload, not automated chart authoring. Cohere functions depend on contracted UM/appeals programs. Redox supports attachments and connection-dependent responses, not a complete staff work queue. Medblocks supplies context for an app, not a PA-specific evidence package.

Do not score breadth from the table alone

Requirement detection, chart retrieval, clinical synthesis, attachment transport and payer-side evidence review are distinct operations. Decompose them in the RFP. An appeals product elsewhere in an RCM portfolio does not automatically establish medical PA denial appeal support in the authorization module.

70. Appendix: Pricing signals and total cost

No unsourced dollar estimates are assigned to enterprise PA vendors.

Signal	What can be concluded / what remains open
CoverMyMeds provider ePA	No-cost provider/staff usage is published. Confirm current terms and exact workflow. Embedded API licensing and implementation are not priced by that statement. [17][18]
Surescripts portal	Free prescriber/staff portal is published. Network integration and EHR implementation are separate commercial questions. [20]
Medblocks platform	Free: \$0, up to 1,000 active patients. Enterprise: \$60,000/year, uncapped; clinical workflows included. Patient quota counts successful FHIR pulls. This does not buy verified PA routing. [25]
Other evaluated offerings	No numeric enterprise PA rate found in the reviewed pages for Waystar, Infinx, Humata, Availity APIs, Cohere, EviCore or Redox. Obtain comparable written quotes; this is not a claim that no price exists anywhere.

Recommended TCO model

Year-one cost = setup + integration + annual platform/network fees + usage charges + human exception work + internal operations + security/compliance effort + training. Steady-state cost replaces initial setup with maintenance and change management. Keep vendor pass-through costs and internal labor visible.

Illustrative sensitivity only, not a vendor estimate: 10,000 cases/month, 12 staff minutes/case and \$30/hour loaded labor imply \$60,000/month baseline labor. If a pilot measures a net 40% reduction in total touch time, gross capacity value is \$24,000/month (\$288,000/year). A hypothetical \$180,000 annual total incremental cost leaves \$108,000 capacity value. Capacity is not cash savings unless staffing or throughput actually changes.

At 20%, 40% and 60% touch-time reduction, the same example yields \$144,000, \$288,000 and \$432,000 annual capacity value. Break-even against \$180,000 is 25%. Measure net effort including review, failures and vendor management; do not add overlapping denial-recovery or revenue benefits without a defensible baseline.

71. References and research transparency

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[01] CMS: CMS-0057-F fact sheet

<https://www.cms.gov/newsroom/fact-sheets/cms-interopability-prior-authorization-final-rule-cms-0057-f>

Final-rule scope and timing; do not generalize to every payer or drug. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[02] CMS: Electronic Prior Authorization

<https://www.cms.gov/priorities/electronic-prior-authorization/overview>

Current policy directory; CMS-0062-P is identified as proposed at review. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[03] HL7: Da Vinci PAS 2.2.1

<https://hl7.org/fhir/us/davinci-pas/2.2.1/en/index.html>

Published PA exchange guide; vendor conformance must be established separately. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[04] Waystar: Authorization Manager

<https://www.waystar.com/our-platform/financial-clearance/authorizations/>

Product modules and EHR/HIS/PM positioning. Vendor claims, not independent benchmark results. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[05] Infinx: PA software and services

<https://www.infinx.com/prior-authorization-solution-ai-and-automation/>

Determination, submission, follow-up, portal, EHR updates and human exception handling. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[06] Infinx: Revenue cycle automation agents

<https://www.infinx.com/revenue-cycle-automation-agents/>

Additional channel context: automation including payer-portal interaction. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[07] Humata Health: product portfolio

<https://www.humatahealth.com/>

Medical services, drugs and payer offerings; policy matching, bundling, submission support and statusing. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

72. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[08] Humata: Oklahoma WISer provider resources

<https://www.humatahealth.com/oklahoma-provider-wiser-resources>

Specific program portal, registration and determination-letter workflow. Do not extrapolate to all products. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[09] Availity: provider authorizations

<https://www.availity.com/authorizations/>

Essentials web workflow: requirement checks, creation, supporting documents and pending-case dashboard. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[10] Availity: API Marketplace

<https://www.availity.com/API-Marketplace/>

PA create/status/attachments and CRD/PAS product listings; route/version proof still required. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[11] Availity: multi-payer portal

<https://www.availity.com/multi-payer-portal/>

Portal positioning and commercial context; not evidence that every API is free. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[12] Cohere Health: health-plan solutions

<https://www.coherehealth.com/solutions/health-plan>

UM, delegated/in-house models and Cohere Connect CRD/DTR/PAS claims. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[13] Cohere Health: provider solutions

<https://www.coherehealth.com/solutions/providers>

Provider participation and clinical workflow positioning; scope follows payer programs. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[14] EviCore: provider hub

<https://www.evicore.com/provider>

Create case, upload additional clinical and clinical consultation resources. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

73. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[15] EviCore: getting started

<https://www.evicore.com/faqs/providers/getting-started>

Portal selection depends on health plan and solution. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[16] EviCore: provider resources

<https://www.evicore.com/resources>

Health-plan-specific onboarding and training resources. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[17] CoverMyMeds: provider solutions

<https://marketingbuilder.covermymeds.com/solutions/provider/>

Vendor-hosted page states no cost to providers/staff and EHR workflows. Integration list contains legacy references; reconfirm current availability. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[18] CoverMyMeds: developers

<https://marketingbuilder.covermymeds.com/support/developers/>

Provider ePA integration and pharmacy NCPDP Telecom interface; access by request. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[19] Surescripts: Electronic Prior Authorization

<https://surescripts.com/products/electronic-prior-authorization>

Medication ePA product positioning and free provider portal. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[20] Surescripts: portal resource center

<https://surescripts.com/prior-authorization-portal-resources>

Explicit free prescriber/staff medication PA portal signal. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[21] Surescripts: ePA companion guide

<https://docs.surescripts.com/electronic-prior-auth/guide>

NCPDP SCRIPT-based implementation documentation for PBM/payers and provider vendors. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

74. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[22] Surescripts: ePA message flow

<https://docs.surescripts.com/electronic-prior-auth/guide/electronic-prior-authorization-message-flow>

Network message-flow detail; does not establish a commercial entitlement. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[23] Redox: submit prior authorization

<https://docs.redoxengine.com/fhir-api-actions/financial/submit-prior-authorization/>

API contract, digital connection prerequisite, attachments and sync/async response dependencies; updated 23 Feb 2026. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[24] Medblocks: clinician workflow

<https://medblocks.com/docs/clinician-workflow>

SMART/CDS Hooks EHR-context capability. Page explicitly marks these docs work in progress. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[25] Medblocks: billing and plans

<https://medblocks.com/docs/billing>

Public Free and Enterprise list prices; this is infrastructure pricing, not a PA submission quote. | Publication/update date not stated unless noted above; reviewed 30 Sep 2026.

[26] Medblocks: introduction

<https://medblocks.com/docs>

Current product surfaces, SDK/API and workspace tools | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[27] Medblocks: how it works

<https://medblocks.com/docs/how-medblocks-works>

Source, authorized connection, pull and export concepts | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[28] Medblocks: sources and connections

<https://medblocks.com/docs/sources-and-connections>

Source catalog and authorized connection lifecycle | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

75. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[29] Medblocks: patient access

<https://medblocks.com/docs/patient-access>

Patient-mediated authorization and source guides | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[30] Medblocks: backend

<https://medblocks.com/docs/backend>

Organization-authorized background access; WIP documentation | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[31] Medblocks: network

<https://medblocks.com/docs/network>

Permitted relationships/purposes and network integration; WIP | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[32] Medblocks: data out

<https://medblocks.com/docs/data-out>

Stored resource reads, dashboard-managed exports, independent export runs | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[33] Medblocks: pull monitoring

<https://medblocks.com/docs/pull-monitoring>

Asynchronous retrieval, refresh failure and dashboard history | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[34] Medblocks: webhooks

<https://medblocks.com/docs/webhooks>

Event types, raw-body signature validation and 5-second acknowledgment; fetched directly when browser retrieval failed | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[35] Medblocks: clinical domain models

<https://medblocks.com/docs/clinical-data-models>

Source-aware clinical shapes and provenance; direct page retrieval used | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

76. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[36] Medblocks: the Medblocks Stack

<https://medblocks.com/medblocks-ui-docs/the-medblocks-stack>

Separate DHP/openEHR/FHIR/SMART/S3 design material; not proof of Connect internals | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[37] Medblocks: original openFHIR repository

<https://github.com/medblocks/openFHIR>

Archive and successor pointer; Apache-2.0 | Archived 5 Mar 2026; reviewed 30 Sep 2026.

[38] openFHIR: successor repository

<https://github.com/openFHIR/openfhir>

FHIRConnect mapping, Apache-2.0, explicit open-source production limitations | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[39] Medblocks: openFHIR announcement

<https://medblocks.com/blog/announcing-medblocks-openfhir-an-open-source-engine-that-bridges-openehr-and-fhir>

Historical mapping-engine positioning; current repository status takes precedence | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[40] HL7: FHIR publication directory

<https://hl7.org/fhir/directory.html>

R4, R4B, R5 and R6 development version distinction | R5 26 Mar 2023; R6 snapshot 17 Jul 2026; reviewed 30 Sep 2026.

[41] HL7: US Core 6.1.0

<https://hl7.org/fhir/us/core/STU6.1/>

R4 profiles and USCDI alignment; partner baseline, not claim of newest version | Active 19 Jun 2023; reviewed 30 Sep 2026.

[42] HealthIT.gov: all USCDI versions

<https://isp.healthit.gov/all-uscdi-versions>

Dataset version directory; published data scope is distinct from regulation | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

77. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[43] ONC: Standards Bulletin 2024-1

https://www.healthit.gov/sites/default/files/page/2024-01/Standards_Bulletin_2024-1.pdf

HTI-1 USCDI v3 baseline from 1 Jan 2026 within certification program | Jan 2024; reviewed 30 Sep 2026.

[44] HL7: SMART App Launch 2.2.0

<https://hl7.org/fhir/smart-app-launch/STU2.2/>

Launch, discovery, backend, scopes and authentication patterns | Generated 30 Apr 2024; reviewed 30 Sep 2026.

[45] HL7: SMART Backend Services

<https://hl7.org/fhir/smart-app-launch/STU2.2/backend-services.html>

Asymmetric client authentication and preauthorized system access | SMART 2.2.0; reviewed 30 Sep 2026.

[46] IETF: RFC 9700 OAuth security BCP

<https://www.rfc-editor.org/rfc/rfc9700.html>

Modern OAuth protections and prohibition on resource-owner-password grant | Jan 2025; reviewed 30 Sep 2026.

[47] OpenID Foundation: OIDC Core 1.0

https://openid.net/specs/openid-connect-core-1_0.html

Identity layer, ID token and claims | Errata set 2; reviewed 30 Sep 2026.

[48] HL7: Bulk Data Access STU2

<https://hl7.org/fhir/uv/bulkdata/STU2/>

Asynchronous export and NDJSON patterns | Version 2.0.0; reviewed 30 Sep 2026.

[49] HL7: Subscriptions Backport STU1.1

<https://hl7.org/fhir/uv/subscriptions-backport/STU1.1/>

Version-specific event notification framework | Version 1.1.0; reviewed 30 Sep 2026.

78. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[50] HL7: C-CDA

<https://hl7.org/cda/us/ccda/>

Clinical document standard; negotiate deployed version | Reviewed page labels v5.0.0; reviewed 30 Sep 2026.

[51] HL7: DocumentReference R4

<https://hl7.org/fhir/R4/documentreference.html>

Document metadata versus content/binary, provenance | FHIR 4.0.1; reviewed 30 Sep 2026.

[52] HL7: terminology service R4

<https://hl7.org/fhir/R4/terminology-service.html>

CodeSystem, ValueSet, ConceptMap operations | FHIR 4.0.1; reviewed 30 Sep 2026.

[53] HealthIT.gov: TEFCA

<https://healthit.gov/policy/tefca/>

Exchange framework, purposes and trust | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[54] Carequality: framework overview

<https://carequality.org/what-we-do/>

Legal, policy, technical and governance framework | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[55] CommonWell: connect to the network

<https://www.commonwellalliance.org/connect-to-the-network>

Network onboarding and record-location services | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[56] Epic: OAuth documentation

<https://fhir.epic.com/Documentation?docId=oauth2>

Launch/backend OAuth and sandbox context; verify per-site contract | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

79. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[57] Oracle: Millennium API catalog

<https://docs.oracle.com/en/industries/health/millennium-platform-apis/apis.html>

R4 and other API families; avoid assuming retired versions supported | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[58] Oracle: authorization framework

<https://docs.oracle.com/en/industries/health/millennium-platform-apis/authorization-framework/>

SMART, OAuth and refresh behavior | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[59] athenahealth: athenaOne CDS Hooks guide

<https://docs.athenahealth.com/downloads/athenaone-cds-hooks-integration-guide>

athenaOne workflow integration and client-credentials context | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[60] athenahealth: athenaPractice/athenaFlow security

<https://e2e.docs.mydata.athenahealth.com/fhir-r4/security.html>

Product-specific auth; observed password-grant recommendation conflicts with RFC 9700 | Guide v27.0.0; index active 18 Sep 2026; reviewed 30 Sep 2026.

[61] eClinicalWorks: interoperability

<https://www.eclinicalworks.com/products-services/interoperability/>

FHIR, provider SMART and bulk/backend developer entry points | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[62] MEDITECH: Greenfield Workspace

<https://ehr.meditech.com/ehr-solutions/greenfield-workspace>

Developer testing, patient R4 and integration surfaces | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[63] MEDITECH: Greenfield resources

<https://ehr.meditech.com/ehr-solutions/greenfield-workspace-resources>

Environment/product scope and onboarding constraints | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

80. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[64] CMS: Blue Button API documentation

<https://bluebutton.cms.gov/api-documentation/>

Patient-authorized Medicare claims data and synthetic sandbox | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[65] UnitedHealthcare: PA and notification

<https://www.uhcprovider.com/en/prior-auth-advance-notification.html>

Provider portal submission and advertised PA API status check | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[66] Aetna: interoperability developer portal

<https://developerportal.aetna.com/>

FHIR R4, SMART/OAuth and registration; not proof of route-specific PAS | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[67] Blue Cross NC: interoperability APIs

<https://www.bcbsnc.com/policies-best-practices/api-access>

Provider Access and Prior Authorization explicitly marked Coming 2027 | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[68] CMS: enforcement and compliance FAQs

<https://www.cms.gov/priorities/key-initiatives/burden-reduction/administrative-simplification/enforcement/faqs>

Scoped all-FHIR alternative to X12 278 enforcement | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[69] HL7: CRD 2.2.1

<https://hl7.org/fhir/us/davinci-crd/2.2.1/en/index.html>

Coverage discovery, actors, supported US Core baselines | Active 27 Mar 2026; reviewed 30 Sep 2026.

[70] HL7: DTR 2.2.0 specification

<https://hl7.org/fhir/us/davinci-dtr/2.2.0/en/specification.html>

Documentation workflow, SMART app and rules | Version 2.2.0; reviewed 30 Sep 2026.

81. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[71] HL7: DTR questionnaire-package

<https://hl7.org/fhir/us/davinci-dtr/2.2.0/en/OperationDefinition-questionnaire-package.html>

Parameters output containing questionnaire package Bundles | Version 2.2.0; reviewed 30 Sep 2026.

[72] HL7: PAS 2.2.1 specification

<https://hl7.org/fhir/us/davinci-pas/2.2.1/en/specification.html>

Submission lifecycle and technical contracts | Version 2.2.1; reviewed 30 Sep 2026.

[73] HL7: PAS Claim/\$submit

<https://hl7.org/fhir/us/davinci-pas/2.2.1/en/OperationDefinition-Claim-submit.html>

Submission operation | Version 2.2.1; reviewed 30 Sep 2026.

[74] HL7: PAS Claim/\$inquire

<https://hl7.org/fhir/us/davinci-pas/2.2.1/en/OperationDefinition-Claim-inquiry.html>

Inquiry operation | Version 2.2.1; reviewed 30 Sep 2026.

[75] HL7: PAS additional information

<https://hl7.org/fhir/us/davinci-pas/2.2.1/en/additionalinfo.html>

Task/CDex additional-documentation flow | Version 2.2.1; reviewed 30 Sep 2026.

[76] HHS: Security Rule summary

<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

Current safeguards, risk analysis, HITECH and organizational requirements | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[77] HHS: Security Rule NPRM

<https://www.hhs.gov/hipaa/for-professionals/security/hipaa-security-rule-nprm/index.html>

Proposal distinguished from rule currently in effect | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

82. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[78] HHS: Privacy Rule summary

<https://www.hhs.gov/hipaa/for-professionals/privacy/laws-regulations/index.html>

Permitted uses, rights and privacy governance | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[79] HHS: minimum necessary

<https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/minimum-necessary-requirement/index.html>

Purpose-based minimization and exceptions including treatment disclosures | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[80] HHS: business associate contracts

<https://www.hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html>

BAA scope, subcontractors, return/destruction and incident obligations | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[81] HHS: breach notification

<https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html>

Investigation, notice obligations and timelines | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[82] AICPA: SOC services

<https://www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services>

SOC assurance and trust-services context | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[83] HITRUST: assurance framework

<https://hitrustalliance.net/>

Framework and assessment/certification distinction | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[84] NLM: SNOMED CT licensing

https://www.nlm.nih.gov/healthit/snomedct/snomed_licensing.html

Clinical terminology licensing/distribution conditions | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

83. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[85] LOINC: license

<https://loinc.org/kb/license>

Observation terminology and licensing conditions | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[86] NLM: RxNorm overview

<https://www.nlm.nih.gov/research/umls/rxnorm/overview.html>

Normalized drug concepts and source mappings | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[87] CMS: code sets

<https://www.cms.gov/priorities/key-initiatives/burden-reduction/administrative-simplification/code-sets>

Diagnosis/procedure code-set roles | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[88] CMS: coding/classification systems

<https://www.cms.gov/cms-guide-medical-technology-companies-and-other-interested-parties/coding/overview-coding-classification-systems>

CPT/HCPCS, ICD and ownership/licensing context | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[89] FDA: NDC directory

<https://www.fda.gov/drugs/drug-approvals-and-databases/national-drug-code-directory>

Drug product codes; listing is not FDA approval | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[90] HAPI FHIR: JPA server

https://hapifhir.io/hapi-fhir/docs/server_jpa/introduction.html

Persistence/server architecture; moving docs do not pin deployable release | Page updated 18 Sep 2026; reviewed 30 Sep 2026.

[91] HAPI FHIR: partitioning

https://hapifhir.io/hapi-fhir/docs/server_jpa_partitioning/partitioning.html

Partitioning/multitenancy must be paired with authorization | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

84. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[92] LinuxForHealth: FHIR repository

<https://github.com/LinuxForHealth/FHIR>

Open-source alternative and Apache-2.0 licensing; maintenance fit requires diligence | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[93] AWS: HealthLake data stores

<https://docs.aws.amazon.com/healthlake/latest/devguide/managing-data-stores.html>

Managed R4 data store; SMART or SigV4 authorization | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[94] AWS: HealthLake for EHRs

<https://docs.aws.amazon.com/healthlake/latest/devguide/reference-industry-ehrs.html>

Managed-service capability context; validate exact operations/IG support | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[95] AWS: HIPAA eligible services

<https://aws.amazon.com/compliance/hipaa-eligible-services-reference/>

BAA and service eligibility under shared responsibility | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[96] AWS: SQS at-least-once delivery

<https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/standard-queues-at-least-once-delivery.html>

Duplicate delivery motivates idempotent consumers | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[97] HealthIT.gov: Inferno PAS test kit

<https://inferno.healthit.gov/test-kits/davinci-pas/>

Actor-specific validation tool; no test executed for this blueprint | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[98] HL7 Da Vinci: paired payer reference

<https://github.com/HL7-DaVinci/br-payer>

Reference implementation, not production payer or certification | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

85. References and research transparency (continued)

Official primary sources. Review date: 30 September 2026. Click title or URL; undated sources are identified explicitly.

[99] HL7 Da Vinci: paired provider reference

<https://github.com/HL7-DaVinci/br-provider>

Provider counterpart for synthetic lab validation | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[100] Medblocks: API reference

<https://medblocks.com/docs/reference/api>

Official reference entry point; API operational surface, not PA capability | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[101] Medblocks: workspace setup

<https://medblocks.com/docs/workspace>

Sandbox/production boundaries, server-side API keys and key lifecycle | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[102] Medblocks: security and compliance

<https://medblocks.com/docs/security-and-compliance>

Vendor-published posture and request for formal security packet; not independently audited here | Publication/update date not stated on reviewed page; reviewed 30 Sep 2026.

[103] HL7: v2-to-FHIR message maps

https://www.hl7.org/fhir/uv/v2mappings/message_maps.html

Informative mappings for patient administration, orders, results, documents and scheduling | Guide v1.0.0; reviewed 30 Sep 2026.